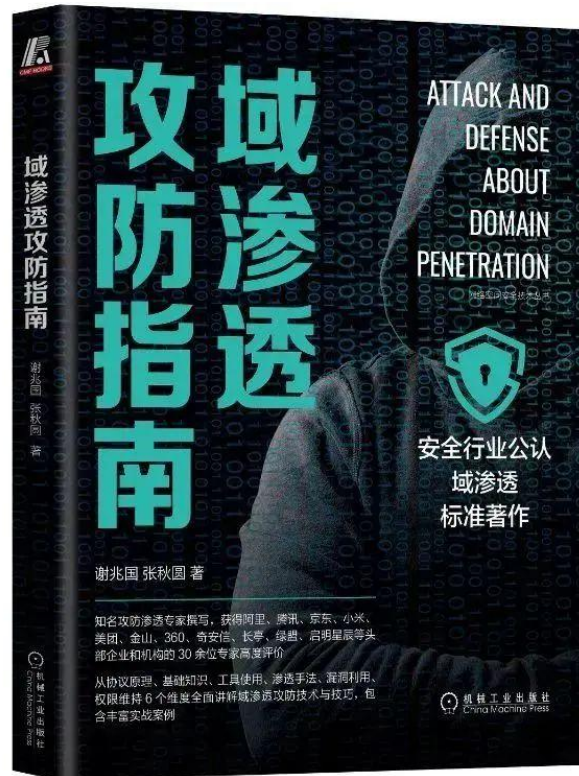


域中的 ACL 访问控制列表

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

在学习域的过程中，我们经常会看到访问控制列表(ACL, Access Control Lists)，对这个词既熟悉又陌生。现在，就让我们来看看 ACL 到底是什么，这需从 Windows 的访问控制模型开始说起。而说 Windows 的访问控制模型之前，我们先来看看两个基础的概念。

安全主体 Security Principals

我们先来看看什么是安全主体 Security Principals。安全主体是可以通过系统进行身份验证的任何实体，例如用户帐户、计算机帐户，或在用户或计算机帐户的安全上下文中运行的线程或进程，以及这些帐户的安全组。每个安全主体在创建时都会自动分配一个安全标识符(SID)。安全主体是控制对安全资源的访问的基础。在活动目录域中创建的安全主体是活动目录对象，可用于管理对域资源的访问。

安全标识符 SID

安全标识符(Security Identifiers, SID)用于唯一标识安全主体或安全组。在帐户的安全上下文中运行的每个帐户、组或进程都有一个唯一的 SID，它由当局发布，例如 Windows 域控制器。它被存储在一个安全数据库中。系统将生成在创建该帐户或组时标识该特定帐户或组的 SID。当 SID 被用作用户或组的唯一标识符时，它再也不能被用于标识其他用户或组。除了分配给特定用户和组唯一创建的、特定于领域的 SID 外，还有一些众所周知的 SID 可以识别通用组和通用用户的 SID。众所周知的 SID 在所有操作系统中都保持不变。SID 是 Windows 安全模型的一个基本构建模块，它与 Windows 服务器操作系统的安全基础设施中的授权和访问控制技术的特定组件一起工作。这有助于保护对网络资源的访问，并提供了一个更安全的计算环境。

如下，是一些众所周知用户的 SID：

- administrator: S-1-5--500
- Guest: S-1-5--501
- KRBTGT: S-1-5--502

如下，是一些众所周知组的 SID：

- Administrators: S-1-5-32-544
- Users: S-1-5-32-545

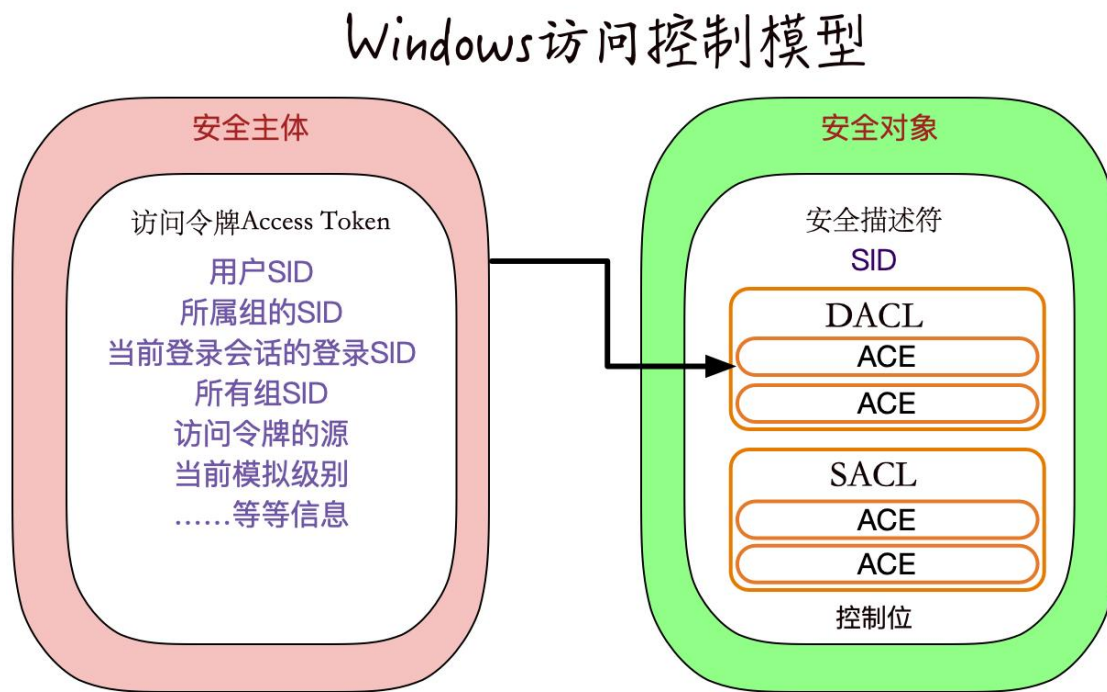
- Guests: S-1-5-32-546
- Account Operators: S-1-5-32-548
- Server Operators: S-1-5-32-549
- Print Operators: S-1-5-32-550
- Backup Operators: S-1-5-32-551
- Domain Admins: S-1-5--512
- Domain Users: S-1-5--513
- Domain Guests: S-1-5--514
- Domain Computers: S-1-5--515
- Domain Controllers: S-1-5--516
- Cert Publishers: S-1-5--517
- Schema Admins: S-1-5--518
- Enterprise Admins: S-1-5--519
- Group Policy Creators Owners: S-1-5--520
- RAS and IAS Servers: S-1-5--553
- Pre-Windows 2000 Compatible Access: S-1-5-32-554

Windows 访问控制模型

访问控制(AC, Access Control)是指控制谁(安全主体, Security Principals)可以访问操作系统中的资源(被访问实体), 这里的访问不仅仅是单纯的访问, 而是包括增删改查等操作。这里的安全主体可以是用户、进程等, 而被访问实体可能是文件、服务、活动目录对象等资源。系统是如何判断安全主体是否对被访问实体具有

权限，并且具有哪些权限呢？这就涉及到 Windows 的访问控制模型(ACM, Access Control Model)了。Windows 的访问控制模型由访问令牌(Access Token)和安全描述符(Security Descriptors)两部分组成。

如图所示，是 Windows 访问控制模型。



1. 访问令牌(Access Token)

用户登录系统时，系统会对用户的帐户名和密码进行身份验证。如果登录成功，系统将创建访问令牌。此后，代表此用户执行的每一个进程都有此访问令牌的副本，访问令牌是描述进程或线程安全上下文的对象。访问令牌包含用户的 SID、用户权限和用户所属的任何组的 SID，还包含用户或用户组拥有的权限列表。当进程尝试访问安全对象或执行需要特权的系统管理任务时，系统使用此访问令牌来标识关联的用户。

访问令牌包含以下信息：

- 用户帐户安全标识符 SID

- 用户所属组的 SID
- 标识当前登录会话的登录 SID
- 用户或 用户组拥有的权限列表
- 所有者 SID
- 主组的 SID
- 用户创建安全对象而不指定安全描述符时系统使用的默认 DACL
- 访问令牌的源
- 令牌是主令牌还是模拟令牌
- 限制 SID 的可选列表
- 当前模拟级别
- 其他统计信息

每个进程都有一个主令牌，用于描述与进程关联的用户帐户的安全上下文。默认情况下，当进程的线程与安全对象交互时，系统将使用主令牌。此外，线程可以模拟客户端帐户，模拟允许线程使用客户端的安全上下文与安全对象进行交互，模拟客户端的线程同时具有主令牌和模拟令牌。

如图所示，可以看到安全主体包含了哪些东西。

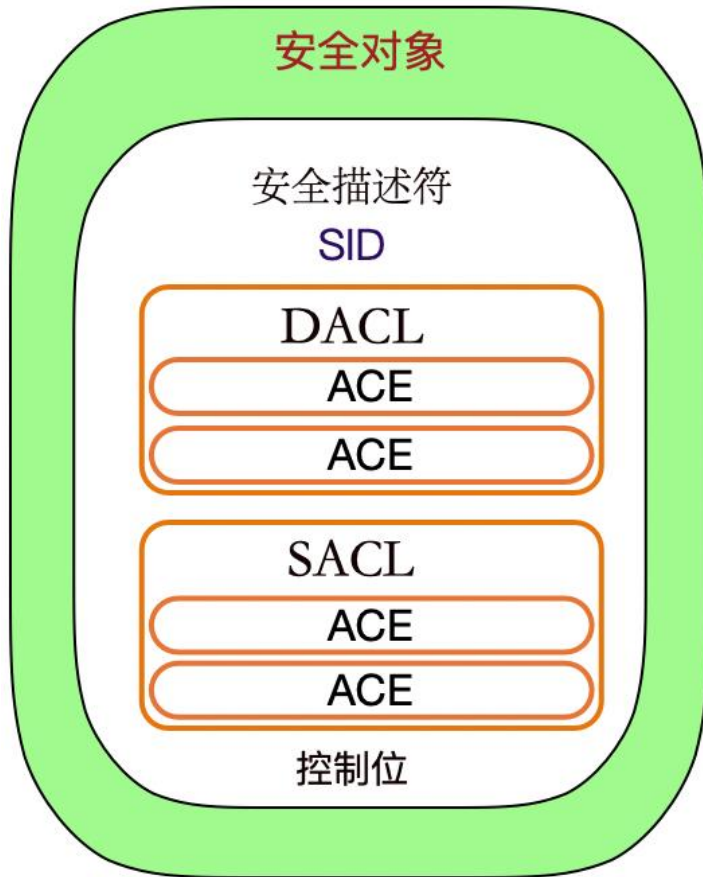


2. 安全描述符(Security Descriptors)

当创建安全对象时，系统会为其分配一个安全描述符 Security Descriptors，其中包含其创建者指定的安全信息；如果未指定任何安全信息，则为其分配默认安全信息。安全描述符可以包含以下安全信息：

- SID(Security Identifiers)：对象的所有者和主组的安全标识符 SID。
- DACL：指定允许或拒绝特定用户或组的访问权限，会在后面详细讲解。
- SACL：指定为对象生成审核记录的访问尝试的类型，会在后面详细讲解。
- 一组控制位 flag：这些控制位限定安全描述符或单个成员的含义。

如图所示，可以看到安全描述符包含了哪些东西。



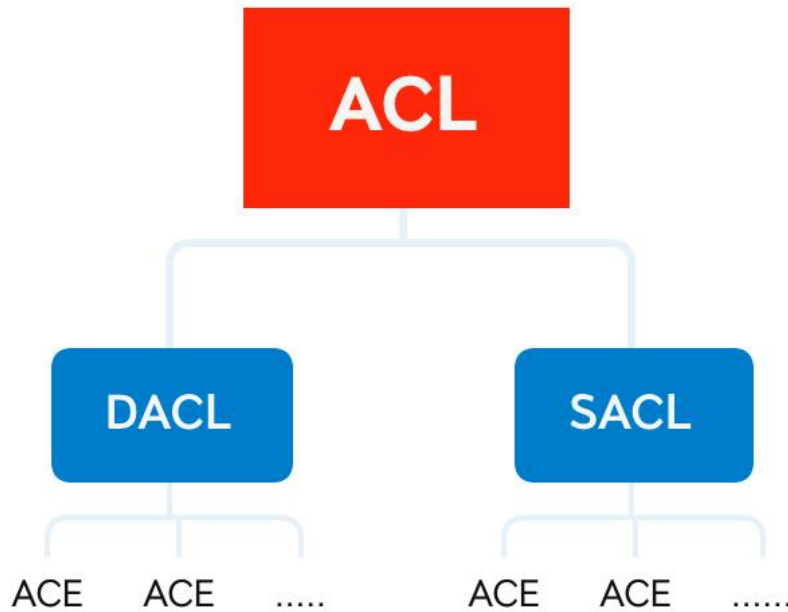
访问控制列表 ACL(Access Control Lists)

访问控制列表(ACL, Access Control Lists)由一系列访问控制条目(ACE, Access Control Entries)组成, 用于定义安全对象的访问策略。而每个访问控制条目 ACE 可以看作是一条策略。每个安全对象的安全描述符包含两种类型的 ACL: DACL 和 SACL。这两种 ACL 中都是由 ACE 组成。

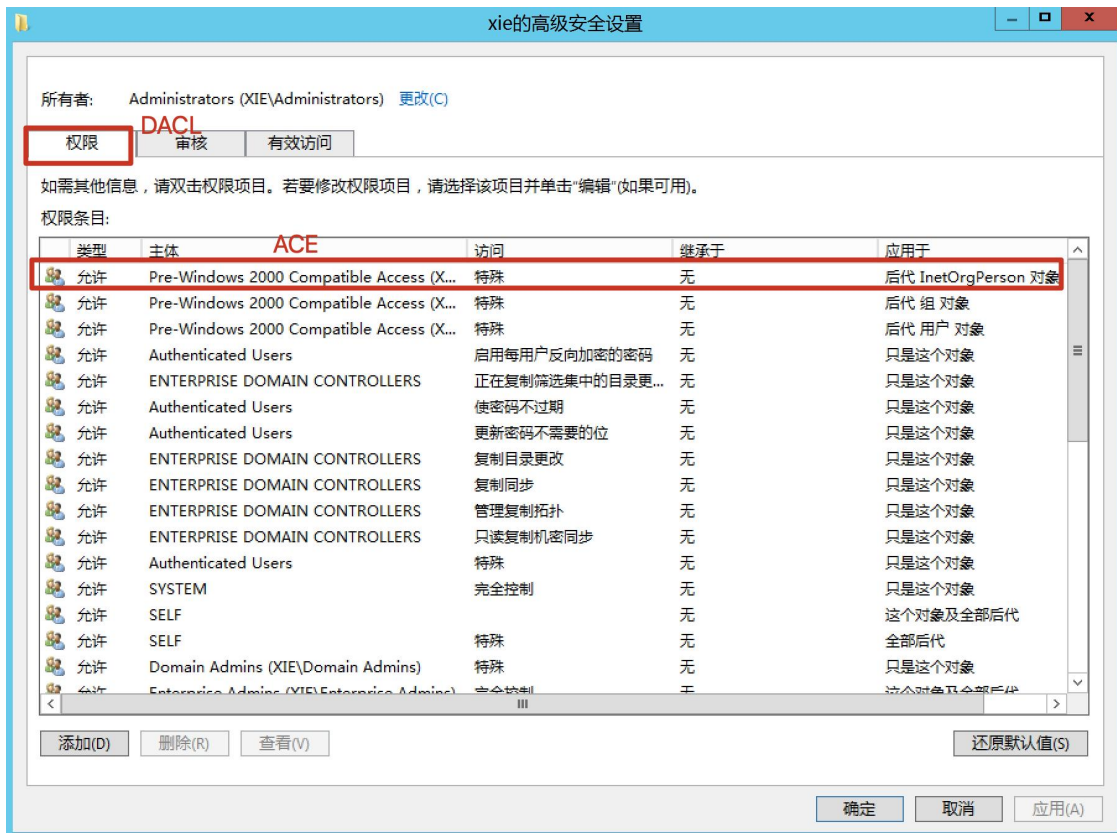
- DACL(Discretionary Access Control List): DACL 能够记录指定安全主体对该安全对象的访问权限。DACL 中的每条 ACE 定义了哪些安全主体对该安全对象具有怎样的访问权限。当安全主体试图访问一个安全对象时, 系统会检查该安全对象 DACL 中的 ACE, 以确定是否授予其访问权限。

- SACL(System Access Control List): SACL 能够记录指定安全主体访问该安全对象的日志。SACL 中的每条 ACE 定义了哪些安全主体对该安全对象访问成功、访问失败的行为进行日志记录。

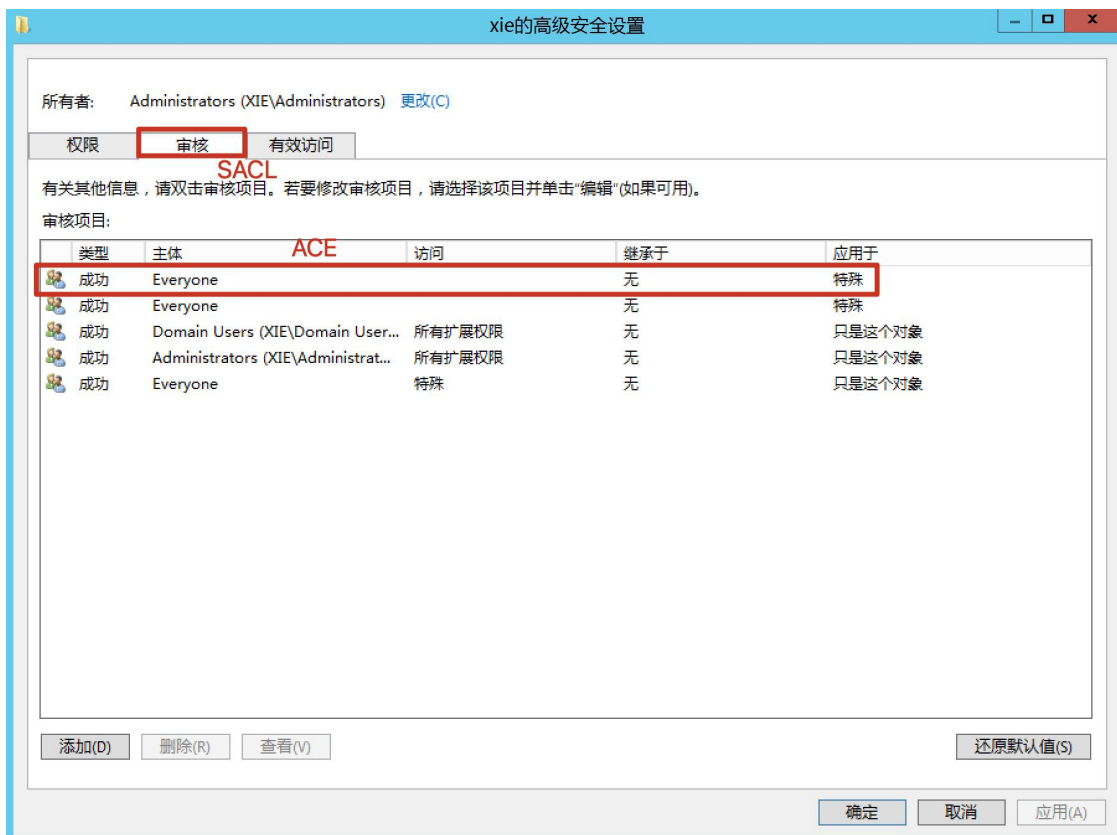
ACL、DACL、SACL 和 ACE 几者之间的关系如图所示。



如图所示，我们查看某个安全对象的访问控制列表 ACE。权限这一栏就是 DACL，下面的每条规则就是每条 ACE。



审核这一栏就是 SACL，下面的每条规则就是每条 ACE。如图所示：



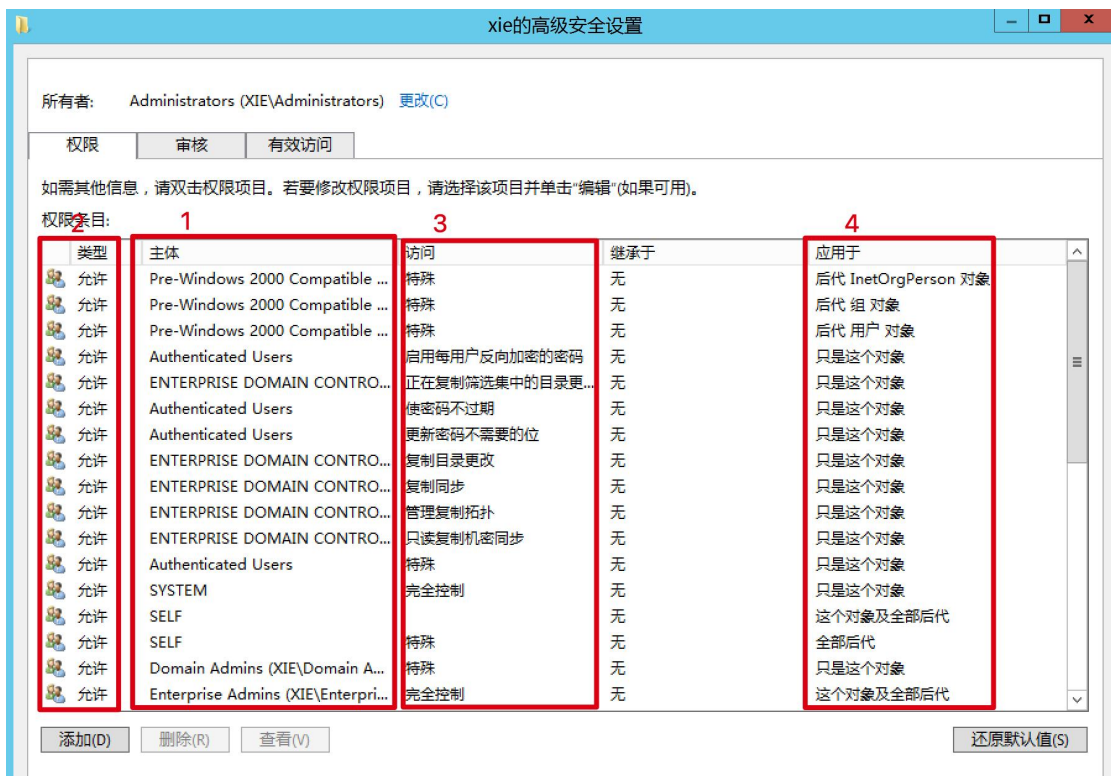
1. 访问控制条目 ACE(Access Control Entries)

访问控制条目(ACE, Access Control Entries)是具体记录访问策略的条目。

ACE 主要记录下面四个方面：

1. 安全主体，也就是谁对该安全对象具有权限
2. 权限的类型，是允许权限还是拒绝权限
3. 具体的权限
4. 该权限能否被继承

如图所示，图形化查看域安全对象 xie.com 的 ACL，打开 Active Directory 用户和计算机窗口，右键 xie.com，点击属性，在弹出的对话框中点击高级即可看到如下。



第一个安全主体这个比较好理解，比如说域用户张三、李四。

第二个权限类型也比较好理解，允许权限还是拒绝权限。

第四个该权限能否被继承也很好理解，就是这个 ACE 能不能被子对象继承。比如我们在 OU 上应用了一个 ACE，如果该 ACE 能被继承，则该 OU 内的用户和组均能继承该 ACE；如果该 ACE 不能被继承，则这条 ACE 只应用于该 OU。

我们着重来看看第三个具体的权限，这里具体权限可以分为三种：

\1) 基本权限：就是对安全对象的基本权限。如图所示：

基本权限:

- ☐ 完全控制
- ☐ 修改
- ☒ 读取和执行
- ☒ 列出文件夹内容
- ☒ 读取
- ☐ 写入
- ☐ 特殊权限

基本权限包括泛型权限和通用权限。如修改、读取、写入、完全控制、修改所有者、修改 DACL 等权限。

泛型权限

- - GENERIC _ READ: 读取对象维护的信息的权利。
 - GENERIC _ WRITE: 写入由 对象维护的信息的权利。
 - GENERIC _ EXECUTE: 执行或查看对象的权利。
 - GENERIC _ ALL: 读取、写入和执行对象的权利。

通用权限适用于所有对象类型:

- - DELETE: 删除对象的权利。
 - READ _ CONTROL: 读取对象的信息。
 - WRITE _ DACL: 修改对象的 DACL 信息。
 - WRITE _ OWNER: 修改对象的所有者 SID 的权利。

— SYNCHRONIZE：在给定对象上等待。

\2) 对属性的权限：域中每个安全对象对应于一个条目，一个条目包含若干个属性，基本权限是对整个条目的权限，域内的 ACL 同时也支持对某个属性的权限。

如图所示：

属性：

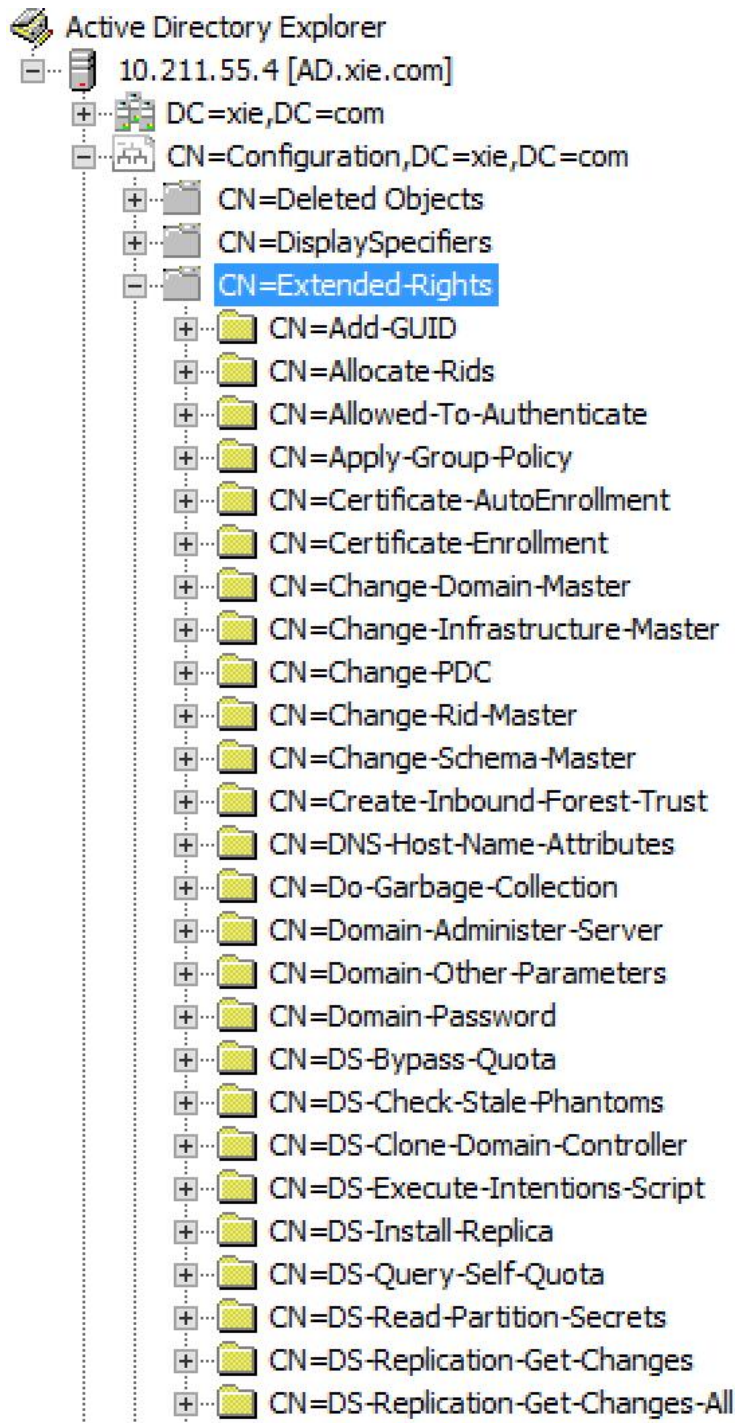
- | | |
|--|--|
| ☐ 读取全部属性 | ☒ 写入 msDS-RevealedUsers |
| ☒ 写入全部属性 | ☐ 读取 msDS-RevealOnDemandGroup |
| ☐ 读取 DNS 主机名属性 | ☒ 写入 msDS-RevealOnDemandGroup |
| ☒ 写入 DNS 主机名属性 | ☐ 读取 msDS-SecondaryKrbTgtNumber |
| ☐ 读取 MS-TS-GatewayAccess | ☒ 写入 msDS-SecondaryKrbTgtNumber |
| ☒ 写入 MS-TS-GatewayAccess | ☐ 读取 msDS-Site-Affinity |
| ☐ 读取 个人信息 | ☒ 写入 msDS-Site-Affinity |
| ☒ 写入 个人信息 | ☐ 读取 msDS-SiteName |
| ☐ 读取 公用信息 | ☒ 写入 msDS-SiteName |
| ☒ 写入 公用信息 | ☐ 读取 msDS-SourceObjectDN |
| ☐ 读取 帐户限制 | ☒ 写入 msDS-SourceObjectDN |
| ☒ 写入 帐户限制 | ☐ 读取 msDS-SupportedEncryptionTypes |
| ☐ 读取 attributeCertificateAttribute | ☒ 写入 msDS-SupportedEncryptionTypes |
| ☒ 写入 attributeCertificateAttribute | ☐ 读取 msDS-SyncServerUrl |
| ☐ 读取 audio | ☒ 写入 msDS-SyncServerUrl |
| ☒ 写入 audio | ☐ 读取 msDS-TasksForAzRoleBL |
| ☐ 读取 businessCategory | ☐ 读取 msDS-TasksForAzTaskBL |
| ☒ 写入 businessCategory | ☐ 读取 msDS-TDOEgressBL |
| ☐ 读取 carLicense | ☐ 读取 msDS-TDOIIngressBL |
| ☒ 写入 carLicense | ☐ 读取 msDS-User-Account-Control-Computed |
| ☐ 读取 department | ☒ 写入 msDS-User-Account-Control-Computed |
| ☒ 写入 department | ☐ 读取 msDS-UserPasswordExpiryTimeComputed |
| ☐ 读取 departmentNumber | ☒ 写入 msDS-UserPasswordExpiryTimeComputed |
| ☒ 写入 departmentNumber | ☐ 读取 msDS-ValueTypeReferenceBL |

\3) 扩展权限：域内的安全对象相对较为复杂，基本权限和对属性的权限不够用，因此域内的 ACL 也支持扩展权限，比如复制目录更改权限、复制目录更改所有项权限等。扩展权限都存储在 CN=Extended-

Rights,CN=Configuration,DC=xie,DC=com 里面。如图所示：

- | | |
|--|---|
| ☐ 删除 msCOM-Partition 对象 | ☐ Allow a DC to create a clone of itself |
| ☒ 创建 msCOM-PartitionSet 对象 | ☐ Run Protect Admin Groups Task |
| ☐ 删除 msCOM-PartitionSet 对象 | ☐ 创建入站林信任 |
| ☐ 创建 msDS-AzAdminManager 对象 | ☒ 复制目录更改 |
| ☐ 删除 msDS-AzAdminManager 对象 | ☒ 复制目录更改所有项 |
| ☐ 创建 msDS-DeviceContainer 对象 | ☐ 复制同步 |
| ☐ 删除 msDS-DeviceContainer 对象 | ☐ 更改 PDC |
| ☐ 创建 msDS-GroupManagedServiceAccount 对象 | ☐ 更新密码不需要的位 |
| ☐ 删除 msDS-GroupManagedServiceAccount 对象 | ☐ 管理复制拓扑 |
| ☐ 创建 msDS-ManagedServiceAccount 对象 | ☐ 恢复逻辑删除 |
| ☐ 删除 msDS-ManagedServiceAccount 对象 | ☐ 监视 Active Directory 复制 |
| ☐ 创建 msDS-QuotaContainer 对象 | ☐ 启用每用户反向加密的密码 |
| ☐ 删除 msDS-QuotaContainer 对象 | ☐ 迁移 SID 历史 |
| ☐ 创建 mslmaging-PSPs 对象 | ☐ 生成策略的结果集(计划) |
| ☐ 删除 mslmaging-PSPs 对象 | ☐ 生成策略的结果集(记录) |
| ☐ 创建 MSMQ 队列别名 对象 | ☐ 使密码不过期 |
| ☐ 删除 MSMQ 队列别名 对象 | ☐ 添加 GUID |

如图所示，通过 ADEplorer 连接活动目录查看 CN=Extended-Rights,CN=Configuration,DC=xie,DC=com 下的扩展权限。



安全

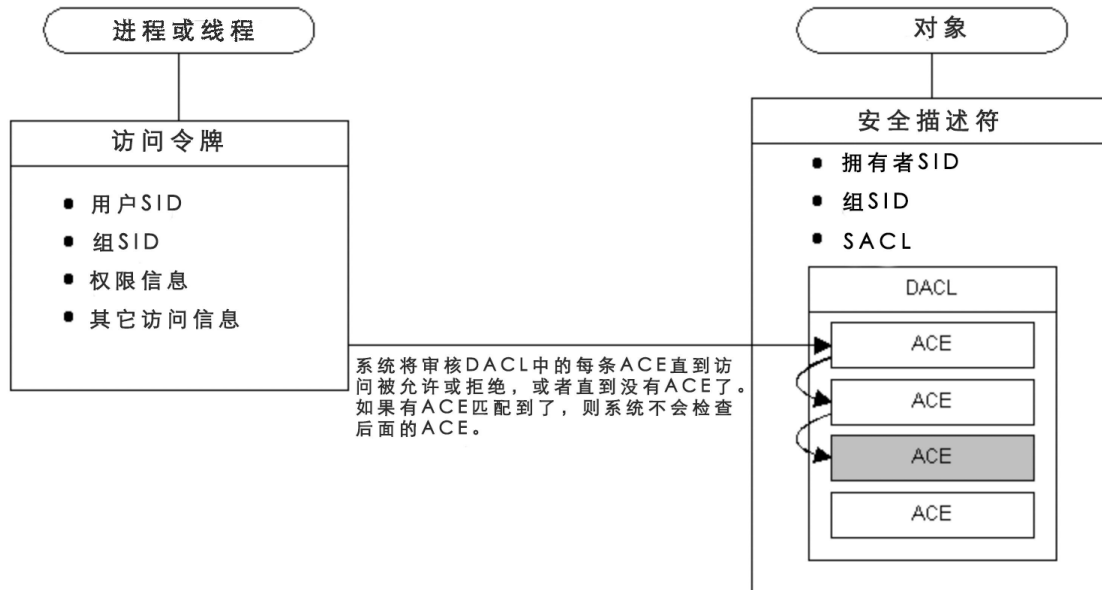
2. ACL 的判断流程

ACL 的解析优先级如下：

- 显式拒绝

- 显式允许
- 继承的拒绝
- 继承的允许

如图所示，显示了这些安全主体访问安全对象时的流程。



系统会按照顺序检查 DACL 中的每条 ACE，直到找到一条或多条允许所有请求访问权限的 ACE，或者直到找到一条或多条拒绝所有访问请求的 ACE。当所有 ACE 都没匹配上的时候，是拒绝访问的。如果该安全对象对象没有 DACL，系统将授予所有人完全的访问权限。如果该对象有 DACL，但是 DACL 中没有 ACE，则系统将拒绝所有人访问该对象，因为该 DACL 不允许有任何访问权限。

我们接下来举个例子来说明一下，以下只是说明下流程，并未说明具体的权限以及继承相关问题。

安全主体 A:

sid=100

groupsid=110

groupsid=120

安全主体 B:

sid=200

groupsid=210

groupsid=220

安全主体 C:

sid=300

groupsid=310

groupsid=320

安全对象 D:

ACE: 拒绝 sid=200 的对象访问

ACE: 允许 sid=100 和 groupsid=210 的对象访问

安全对象 E:

有 DACL, 但是 DACL 中的 ACE 条目为 0

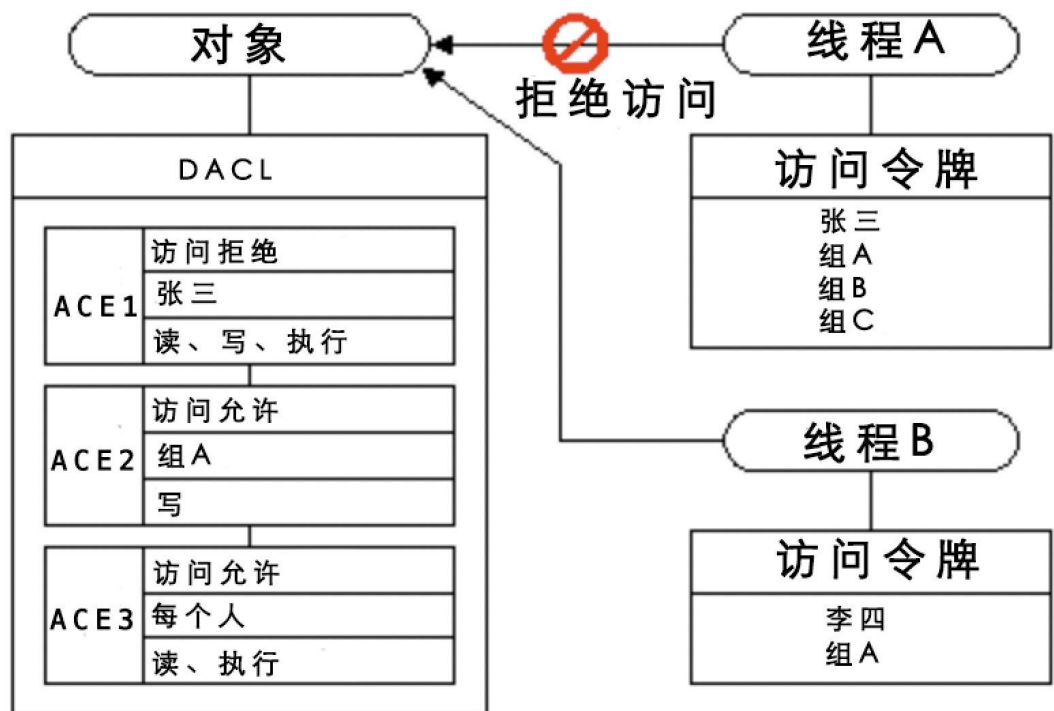
安全对象 F:

无 DACL

- 当安全主体 A 访问安全对象 D 时, 首先匹配第一条拒绝 sid=200 的访问, 没匹配上, 然后匹配第二条允许 sid=100 和 sid=210 的对象访问, 匹配上了, 所以允许安全主体 A 访问。
- 当安全主体 B 访问安全对象 D 时, 首先匹配第一条拒绝 sid=200 的访问, 匹配上了, 于是拒绝安全主体 B 对该安全对象 D 的访问。即使第二条 ACE 允许了 sid=210 的对象访问匹配上了, 但是因为拒绝的 ACE 优先级大于允许的 ACE, 所以最后还是拒绝主体 B 访问。
- 当安全主体 C 访问安全对象 D 时, 第一条 ACE 和第二条 ACE 都没匹配上, 所以拒绝安全主体 C 访问。
- 由于安全对象 E 有 DACL, 但是 DACL 中的 ACE 条目为 0, 所以不允许任何主体访问, 因此安全主体 A、安全主体 B、安全主体 C 均不能访问安全对象 E。

- 由于安全对象 F 无 DACL，因此安全主体 A、安全主体 B、安全主体 C 均能访问安全对象 F。

如图所示，显示了对象的 DACL 如何允许访问一个线程，同时拒绝访问另一个线程。



对于线程 A，系统读取 ACE 1 并立即拒绝访问，因为拒绝访问的 ACE 适用于线程的访问令牌中的用户。在这种情况下，系统不会检查 AES 2 和 3。对于线程 B，ACE 1 不适用，因此系统将继续访问 ACE 2（允许写入访问）和 ACE 3（允许读取和执行访问权限）。

由于系统在显式授予或拒绝请求的访问权限时停止检查 AES，因此 DACL 中的 AES 顺序非常重要。请注意，如果示例中的 ACE 顺序不同，则系统可能授予了对线程 A 的访问权限。对于系统对象，操作系统在 DACL 中定义 AES 的首选顺序。

SDDL 安全描述符定义语言

安全描述符定义语言(SDDL, Security Descriptor Definition Language)是一种定义可以描述对象权限的方法。SDDL 语言格式主要包含以下四个组件：

- Owner (O:)：标识对象的所有者的 SID 字符串。
- Group (G:)：标识对象的所属组的 SID 字符串，Windows 通常忽略此参数(由于兼容性原因，该值仍在安全描述符中)。
- DACL (D:)：包含 DACL 的安全描述符控制标志，DACL 中包含一系列 ACE。
- SACL (S:)：包含 SACL 的安全描述符控制标志，SACL 中包含一系列 ACE。

对象的 ACL 存储在 nTSecurityDescriptor 属性中。因此，我们可以使用如下语句过滤对象的 nTSecurityDescriptor 属性，以查看对象 SDDL 语言格式呈现的 ACL。

AdFind.exe -b "CN=hack,CN=Users,DC=xie,DC=com" nTSecurityDescriptor -sddl

如图所示，使用 adfind 查看查询 nTSecurityDescriptor 属性。

```
C:\Users\Administrator\Desktop>AdFind.exe -b "CN=hack,CN=Users,DC=xie,DC=com" nTSecurityDescriptor -sddl
AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020

Using server: AD.xie.com:389
Directory: Windows Server 2012 R2

dn:CN=hack,CN=Users,DC=xie,DC=com
>nTSecurityDescriptor: [OWNER] DA
>nTSecurityDescriptor: [GROUP] DA
>nTSecurityDescriptor: [DACL] AI(OA;;RP;(4C164200-20C0-11D0-A768-00AA006E0529);;RS)(OA;;RP;(5F202010-79A5-11D0-9020-00C04FC2D4CF);;RS)(OA;;RP;(BC0AC248-6A9B11D0-60AE-405A-B7E8-FF8A58D456D2);;S-1-5-32-560)(OA;;RPWP;(6DB69A1C-9422-11D1-AE8D-0000F80367C1);;S-1-5-32-561)(OA;;RPWP;(5805BC62-BDC9-4428-A5E2-856F-11D0-9819-00AA0040529B);;PS)(OA;;CR;(AB721A56-1E2F-11D0-9819-00AA0040529B);;PS)(OA;;RP;(59BA2F42-79A2-11D0-9020-00C04FC2D3CF);;AU)(OA;;RP;(E48D0154-BCB886-944A-11D1-AE8D-0000F80367C1);;PS)(OA;;RPWP;(E45795B2-9455-11D1-AE8D-0000F80367C1);;PS)(OA;;RPWP;(E45795B3-9455-11D1-AE8D-0000F80367C1);;PS)(A;;CCDC64200-20C0-11D0-A768-00AA006E0529);;[4828CC14-1437-45BC-9807-AD6F015E5F28];;RU)(OA;CIID;RP;(4C164200-20C0-11D0-A768-00AA006E0529);;BF967ABA-0DE6-11D0-A285-00AA003049E2);;RU)(OA;CIID;RP;(BC0AC240-79A9-11D0-9020-00C04FC2D4CF);;[4828CC14-1437-45BC-9807-AD6F015E5F28];;RU)(OA;CIID;RP;(59BA2F42-79A2-11D0-9020-00C04FC2D3CF);;BF967ABA-0DE6-11D0-A285-00AA003049E2);;ED)(OA;CIID;RP;(B7C69E6D-2CC7-11D2-854E-00A0C983F608);;BF967A86-0DE6-11D0-A285-00AA003049E2);;ED)(OA;CIID;WP;(E41B7B93-5E48-46D5-BC6C-4DF4DA78A35);;BF967A86-0DE6-11D0-A285-00AA003049E2);;PS)(OA;CIID;LCPRLORC;[4828CC14-1437-45BC-9807-AD6F015E5F28];;PS)(OA;CIID;RPWP;[91E647DE-D96F-4B70-9557-D63FF4F3CDD8];;PS)(A;CIID;CCDCLCSWRPMDTLOCRSDRCWDW0;[S-1-5-21-11111111-1111-1111-1111-11111111];;PS)(OU;CIID;SA;WP;(F30E3BBE-9FF0-11D1-B603-0000F80367C1);;BF967AA5-0DE6-11D0-A285-00AA003049E2);;WD)(OU;CIID;SA;WP;(F30E3BBE-9FF0-11D1-B603-0000F80367C1);;WD)
>nTSecurityDescriptor: [SACL] AI(OU;CIID;SA;WP;(F30E3BBE-9FF0-11D1-B603-0000F80367C1);;BF967AA5-0DE6-11D0-A285-00AA003049E2);;WD)(OU;CIID;SA;WP;(F30E3BBE-9FF0-11D1-B603-0000F80367C1);;WD)
```

nTSecurityDescriptor 属性的值由以下几部分构成：

- [OWNER]DA

- [GROUP]DA
- [DACL](#)(ACE).....
- [SACL](#)(ACE).....

接下来，我们来看看 ACL 中 ACE 具体的结构和语法。

1. ACE 的结构

ACE 具体的结构及顺序如下，结构间用分号(;)分隔。一个完整的 ACE 有 6 个分号(;)，共分隔 7 个字段，每条 ACE 被括在括号中。

```
ACE_T   ACE_Fl   Righ  Object_   Inherit_Object  Account  (Resource_Att
ype     ags      ts    Guid      _Guid        _Sid     ribute)
```

注：默认情况下，由于 Resource_Attribute 属性是可选的，因此只有 5 个分号(;)，分隔 6 个字段。

各个字段的含义如下：

- ACE_Type：主要说明是什么类型的 ACE，如允许、拒绝、审计等。
- ACE_Flags：主要设置一些标识符。
- Rights：主要说明是什么权限，如可读、可写等。
- Object_Guid：主要说明对象的 GUID 值。
- Inherit_Object_Guid：主要说明继承对象的 GUID 值。
- Account_Sid：主要说明对象的 SID 值。
- Resource_Attribute：主要说明数据类型，是一个可选字段。

下面看一下每个字段的含义以及包含的值。

(1) ACE_Type

ACE_Type 包含的字段和值如下表所示：

ACE_Type ACE_Type 值

字符串

"A"	ACCESS_ALLOWED_ACE_TYPE (允许访问)
"D"	ACCESS_DENIED_ACE_TYPE (拒绝访问)
"OA"	ACCESS_ALLOWED_OBJECT_ACE_TYPE (允许对象访问：仅适用于对象的子集)
"OD"	ACCESS_DENIED_OBJECT_ACE_TYPE (拒绝访问对象：仅适用于对象的子集。)
"AU"	SYSTEM_AUDIT_ACE_TYPE
"AL"	SYSTEM_ALARM_ACE_TYPE
"OU"	SYSTEM_AUDIT_OBJECT_ACE_TYPE
"OL"	SYSTEM_ALARM_OBJECT_ACE_TYPE
"ML"	SYSTEM_MANDATORY_LABEL_ACE_TYPE Windows Server 2003: Not available.
"XA"	ACCESS_ALLOWED_CALLBACK_ACE_TYPE Windows Server 2008, Windows Vista and Windows Server 2003: Not available.
"XD"	ACCESS_DENIED_CALLBACK_ACE_TYPE Windows Server 2008, Windows Vista and Windows Server 2003: Not available.
"RA"	SYSTEM_RESOURCE_ATTRIBUTE_ACE_TYPE Windows Server 2008 R2, Windows 7, Windows Server 2008, Windows Vista and Windows Server 2003: Not available.
"SP"	SYSTEM_SCOPED_POLICY_ID_ACE_TYPE Windows Server 2008 R2, Windows 7, Windows Server 2008, Windows Vista and Windows Server 2003: Not available.

"XU"	SYSTEM_AUDIT_CALLBACK_ACE_TYPE Windows Server 2008 R2, Windows 7, Windows Server 2008, Windows Vista and Windows Server 2003: Not available
"ZA"	ACCESS_ALLOWED_CALLBACK_ACE_TYPE Windows Server 2008 R2, Windows 7, Windows Server 2008, Windows Vista and Windows Server 2003: Not available.
"TL"	SYSTEM_PROCESS_TRUST_LABEL_ACE_TYPE Windows Server 2012, Windows 8, Windows Server 2008 R2, Windows 7, Windows Server 2008, Windows Vista and Windows Server 2003: Not available.
"FL"	SYSTEM_ACCESS_FILTER_ACE_TYPE Windows Server 2016, Windows 10 Version 1607, Windows 10 Version 1511, Windows 10 Version 1507, Windows Server 2012 R2, Windows 8.1, Windows Server 2012, Windows 8, Windows Server 2008 R2, Windows 7, Windows Server 2008, Windows Vista and Windows Server 2003: Not available.

(2) ACE_Flags

ACE 标志：说明这是继承的权限还是显式给定的权限。ACE_Flags 有如下一些值：

ACE flags string	AceFlag value
"CI"	CONTAINER_INHERIT_ACE (容器继承：作为容器（如目录）的子对象继承 ACE 作为显式 ACE)
"OI"	OBJECT_INHERIT_ACE (对象继承：非容器的子对象继承了显式 ACE。)
"NP"	NO_PROPAGATE_INHERIT_ACE (对象继承：非容器的子对象继承了显

式 ACE。)

- "IO" INHERIT_ONLY_ACE(仅限继承: ACE 不适用于本主题, 但可能会通过继承影响子类。)
- "ID" INHERITED_ACE (ACE 是继承的)
- "SA" SUCCESSFUL_ACCESS_ACE_FLAG (成功的访问审计)
- "FA" FAILED_ACCESS_ACE_FLAG (失败的访问审计)
- "TP" TRUST_PROTECTED_FILTER_ACE_FLAG **Windows Server 2016, Windows 10 Version 1607, Windows 10 Version 1511, Windows 10 Version 1507, Windows Server 2012 R2, Windows 8.1, Windows Server 2012, Windows 8, Windows Server 2008 R2, Windows 7, Windows Server 2008, Windows Vista and Windows Server 2003: Not available.**
- "CR" CRITICAL_ACE_FLAG **Windows Server Version 1803, Windows 10 Version 1803, Windows Server Version 1709, Windows 10 Version 1709, Windows 10 Version 1703, Windows Server 2016, Windows 10 Version 1607, Windows 10 Version 1511, Windows 10 Version 1507, Windows Server 2012 R2, Windows 8.1, Windows Server 2012, Windows 8, Windows Server 2008 R2, Windows 7, Windows Server 2008, Windows Vista and Windows Server 2003: Not available.**

(3) Rights

表示由 ACE 控制的访问权限的字符串。此字符串可以是访问权限的十六进制字符串表示, 如"0x7800003F", 也可以是以下字符串的连接。

通用访问权限

访问权限 String 访问权限的值

- "GA" GENERIC_ALL (通用所有权限)
- "GR" GENERIC_READ (通用阅读权限)

"GW"	GENERIC_WRITE (通用写权限)
"GX"	GENERIC_EXECUTE (通用执行权限)

标准访问权限

访问权限 String 访问权限的值

"RC"	READ_CONTROL (阅读控制权限)
"SD"	DELETE (删除权限)
"WD"	WRITE_DACL (修改 DACL 权限)
"WO"	WRITE_OWNER (修改所有者权限)

活动目录服务对象访问权限

访问权限 String 访问权限的值

"RP"	ADS_RIGHT_DS_READ_PROP (活动目录对象读权限)
"WP"	ADS_RIGHT_DS_WRITE_PROP (活动目录对象写权限)
"CC"	ADS_RIGHT_DS_CREATE_CHILD (创建子对象权限)
"DC"	ADS_RIGHT_DS_DELETE_CHILD (删除子对象权限)
"LC"	ADS_RIGHT_CTRL_DS_LIST
"SW"	ADS_RIGHT_DS_SELF
"LO"	ADS_RIGHT_DS_LIST_OBJECT
"DT"	ADS_RIGHT_DS_DELETE_TREE
"CR"	ADS_RIGHT_DS_CONTROL_ACCESS

文件访问权限

访问权限 String 访问权限的值

"FA"	FILE_ALL_ACCESS (文件所有访问权限)
"FR"	FILE_GENERIC_READ (文件通用读权限)

"FW"	FILE_GENERIC_WRITE （文件通用写权限）
"FX"	FILE_GENERIC_EXECUTE （文件通用执行权限）

注册表密钥访问权限

访问权限 String 访问权限的值

"KA"	KEY_ALL_ACCESS （密钥所有访问权限）
"KR"	KEY_READ （密钥阅读权限）
"KW"	KEY_WRITE （密钥写权限）
"KX"	KEY_EXECUTE （密钥执行权限）

强制性标签访问权限

访问权限
访问权限的值
String

"NR"	SYSTEM_MANDATORY_LABEL_NO_READ_UP Windows Server 2008, Windows Vista and Windows Server 2003: Not available.
"NW"	SYSTEM_MANDATORY_LABEL_NO_WRITE_UP Windows Server 2008, Windows Vista and Windows Server 2003: Not available.
"NX"	SYSTEM_MANDATORY_LABEL_NO_EXECUTE_UP Windows Server 2008, Windows Vista and Windows Server 2003: Not available.

(4) Object_Guid

权限对象的 rightsGuid 属性值，如复制目录更改权限，其对应的 rightsGuid 值为 1131f6aa-9c07-11d1-f79f-00c04fc2dcd2。扩展权限对象保存在 CN=Extended-Rights,CN=Configuration,DC=xie,DC=com 里面。下表列出了一些常见的权限对象 rightsGuid 值：

GUID	权限
1131f6aa-9c07-11d1-f79f-	DS-Replication-Get-Changes(复制目录更

00c04fc2dcd2	改扩展权限)
1131f6ad-9c07-11d1-f79f-00c04fc2dcd2	DS-Replication-Get-Changes-All(复制目录更改所有项扩展权限)
ab721a53-1e2f-11d0-9819-00aa0040529b	User-Change-Password(用户更改密码扩展权限)
00299570-246d-11d0-a768-00aa006e0529	User-Force-Change-Password(用户强制更改密码扩展权限)

如图所示，可以看到复制目录更改权限，其对应的 rightsGuid 值为 1131f6aa-9c07-11d1-f79f-00c04fc2dcd2。

Attribute	Syntax	Count	Value(s)
applesTo	DirectoryString	3	bf967a8f-0de6-11d0-a285-00aa003049e2;bf967a87-0de6-11d0-a285-00aa003049e2;19195a5b-6da0-11d0-afdc3-00c04fd930c9
cn	DirectoryString	1	DS-Replication-Get-Changes
displayName	DirectoryString	1	Replicating Directory Changes
distinguishedName	DN	1	CN=DS-Replication-Get-Changes,CN=Extended-Rights,CN=Configuration,DC=xie,DC=com
dSCorePropagationData	GeneralizedTime	1	1601/1/1 7:00:00
instanceType	Integer	1	4
localizationDisplayId	Integer	1	25
name	DirectoryString	1	DS-Replication-Get-Changes
ntSecurityDescriptor	NTSecurityDescriptor	1	D:AI(A;;LCPLOCR::AU)(A;;CCDCLCSWRPWPLOCRRCWDWO;;;EA)(A;;CCDCLCSWRPWPDTLOCRSDRCWDWO;;;SY)(A;CIIID;CCDCLCSWRPWPDTLOCRSDRCWDWO;;;SY)(A;CIIID;CCDCLCSWRPWPDTLOCRSDRCWDWO;;;SY)
objectCategory	DN	1	CN=Control-Access-Right,CN=Schema,CN=Configuration,DC=xie,DC=com
objectClass	OID	2	top;controlAccessRight
objectGUID	OctetString	1	{05793D32-1D74-4A9C-841D-240B84053E41}
rightsGuid	DirectoryString	1	1131f6aa-9c07-11d1-f79f-00c04fc2dcd2
showInAdvancedViewOnly	Boolean	1	TRUE
usnChanged	Integer8	1	0x1066
usnCreated	Integer8	1	0x1066
validAccesses	Integer	1	256
whenChanged	GeneralizedTime	1	2021/10/16 11:24:38
whenCreated	GeneralizedTime	1	2021/10/16 11:24:38

(5) Inherit_object_guid

继承权限对象的 rightsGuid 属性值。

(6) Account_sid

表示 ACE 指定的安全主体的 objectSid 属性值。如，这条 ACE 表示 hack 用于对该安全对象的权限，则 Account_sid 的值就为 hack 用户的 objectSid。

(7) Resource_attribute

可选结构，resource_attribute 仅适用于资源 ace，并且是可选的，指示数据类型的字符串。

2. ACE 的解析

了解了 ACE 的结构顺序以及每个字段的含义后，我们来解析下 ACE 语句。如下，有一条 ACE。

```
(OA;CI;CR;{1131F6AA-9C07-11D1-F79F-00C04FC2DCD2};;S-1-5-21-1313979556-3624129433-4055459191-1105)
```

我们来对其进行分析：

- 第一个 ACE_Type 字段对应的是“OA”值，而“OA”又代表 ACCESS_ALLOWED_OBJECT_ACE_TYPE(允许对象访问)。因此，可以知道这条是允许类型的 ACE。
- 第二个 ACE_Flags 字段对应的是“CI”值，而“CI”又代表 CONTAINER_INHERIT_ACE(容器继承)。因此，可以知道这条 ACE 是容器继承。
- 第三个 Rights 字段对应的是“CR”值，而“CR”又代表 ADS_RIGHT_DS_CONTROL_ACCESS。因此，可以知道这条 ACE 是活动目录对象控制访问权限。
- 第四个 Object_Guid 对应的是“{1131F6AA-9C07-11D1-F79F-00C04FC2DCD2}”值，如图所示，通过查询可以得知其对应的是 DS-Replication-Get-Changes 扩展权限。因此，可以知道这条 ACE 所代表的扩展权限是复制目录更改权限。
- 第五个 Inherit_object_guid 字段是空值，这里我们不管他。
- 第六个 Account_sid 字段对应的是 S-1-5-21-1313979556-3624129433-4055459191-1105 值，如图所示，通过查询得知该 SID 对应的是 xie\hack 用户。因此，可以知道这条 ACE 所指定的安全主体是 xie\hack 用户。

DS-Replication-Get-Changes extended right

12/15/2020 • 2 minutes to read • M D

Extended right needed to replicate changes from a given NC.

Entry	Value
CN	DS-Replication-Get-Changes
Display-Name	Replicating Directory Changes
Rights-GUID	1131f6aa-9c07-11d1-f79f-00c04fc2dcd2

Attribute	Syntax	Count	Value(s)
accountExpires	Integer8	1	0x0
badPasswordTime	Integer8	1	0x0
badPwdCount	Integer	1	0
cn	DirectoryString	1	hack
codePage	Integer	1	0
countryCode	Integer	1	0
distinguishedName	DN	1	CN=hack,CN=Users,DC=xie,DC=com
dSCorePropagationData	GeneralizedTime	2	2021/10/26 10:31:14;1601/1/1 7:00:01
instanceType	Integer	1	4
lastLogoff	Integer8	1	0x0
lastLogon	Integer8	1	2021/10/25 17:10:28
lastLogonTimestamp	Integer8	1	2021/10/16 11:37:36
logonCount	Integer	1	12
name	DirectoryString	1	hack
nTSecurityDescriptor	NTSecurityDescriptor	1	D:AI(OA;;RP;4c164200-20c0-11d0-a768-00aa006e0529;;RS)
objectCategory	DN	1	CN=Person,CN=Schema,CN=Configuration,DC=xie,DC=com
objectClass	OID	4	top;person;organizationalPerson;user
objectGUID	OctetString	1	{908A4F43-E2C4-4994-8728-B1C42507D357}
objectSid	Sid	1	S-1-5-21-1313979556-3624129433-4055459191-1105
primaryGroupID	Integer	1	513
pwdLastSet	Integer8	1	2021/10/16 11:37:28
sAMAccountName	DirectoryString	1	hack
sAMAccountType	Integer	1	805306368
userAccountControl	Integer	1	512
uSNCreated	Integer8	1	0x31E9
uSNCreated	Integer8	1	0x31E5
whenChanged	GeneralizedTime	1	2021/10/16 11:37:36
whenCreated	GeneralizedTime	1	2021/10/16 11:37:28

综上所述，我们可以从这条 ACE 中得到如下权限信息：xie\hack 用户对当前安全对象具有复制目录更改的权限！

官方文档：[ACE Strings](#)

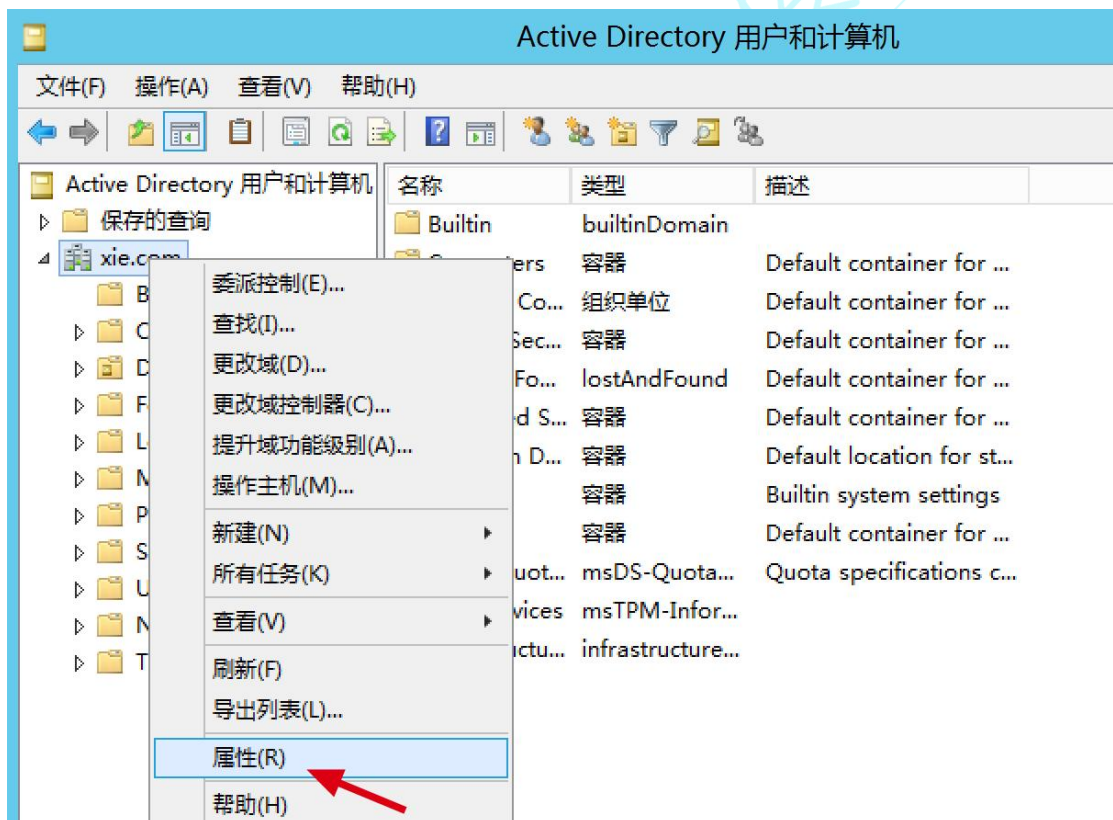
域对象 ACL 的查看和修改

域对象除了具有基本权限外，其还具有属性权限、扩展权限。因此，在域内 ACL 还提供对 Active Directory 目录服务对象的属性权限和扩展权限进行定义。我们现在来看看域对象 ACL 的查看和修改。

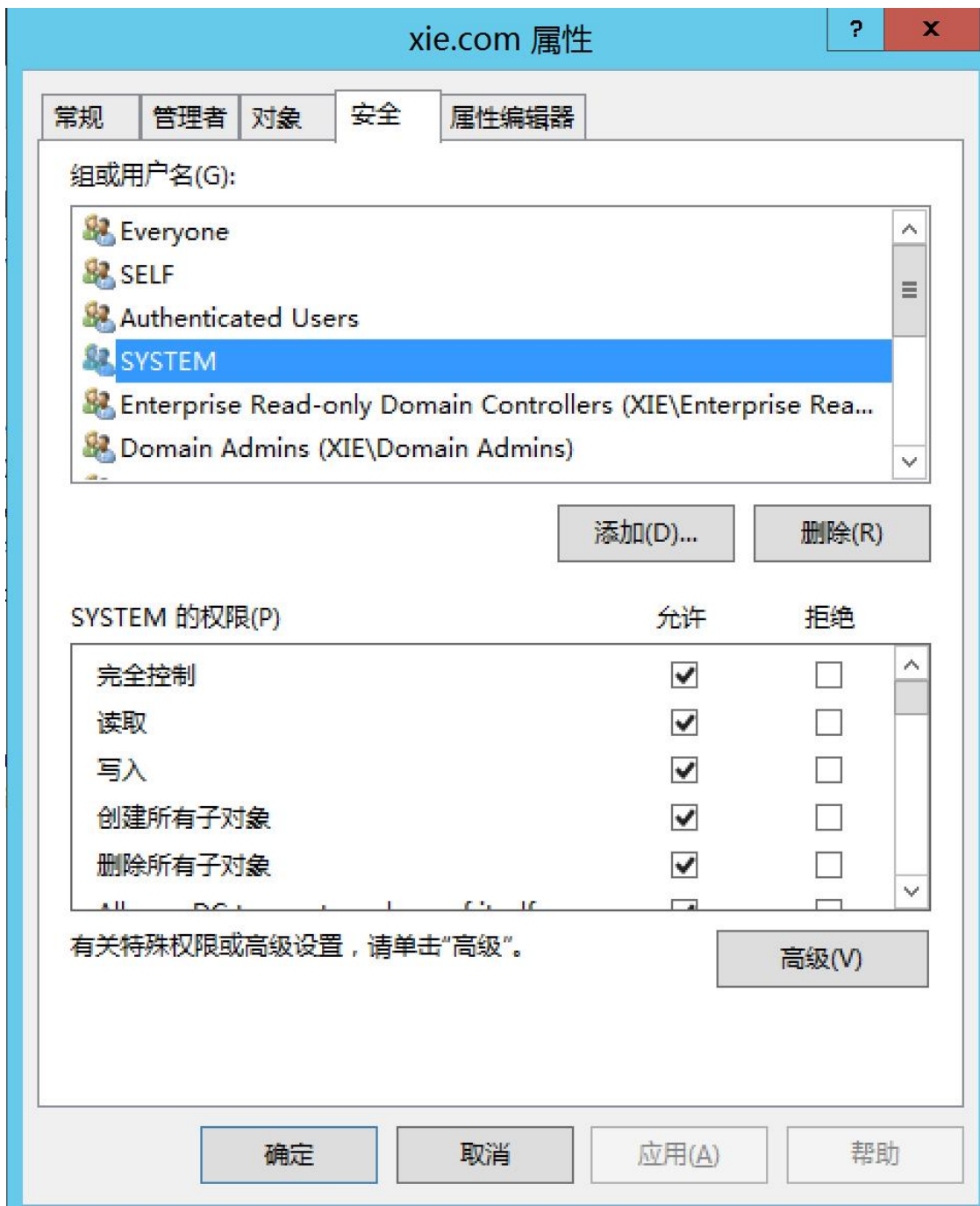
1. 图形化查看和修改

如下操作图形化查看域对象 xie.com 的 ACL。

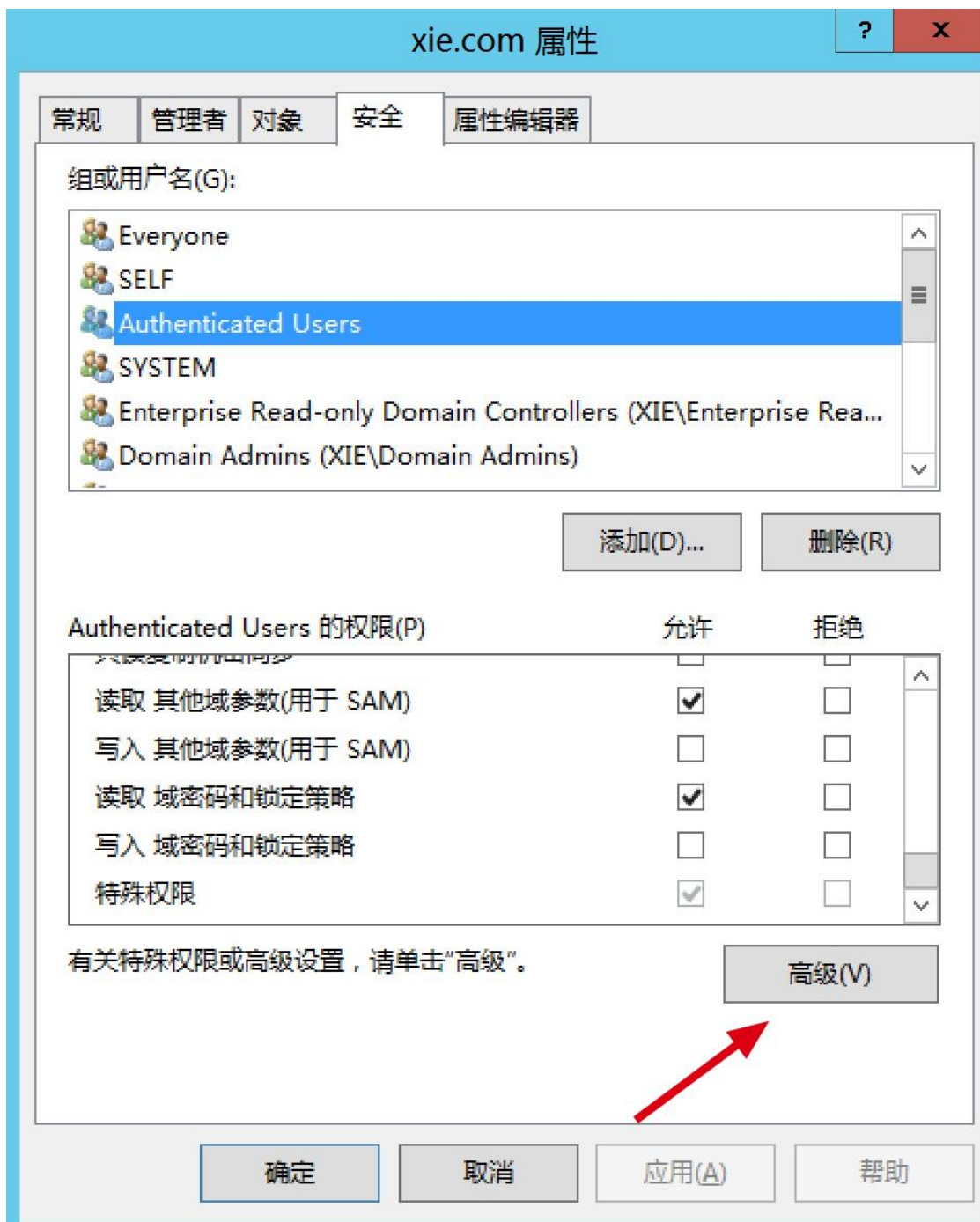
如图所示，打开 Active Directory 用户和计算机窗口，右键 xie.com，点击属性。



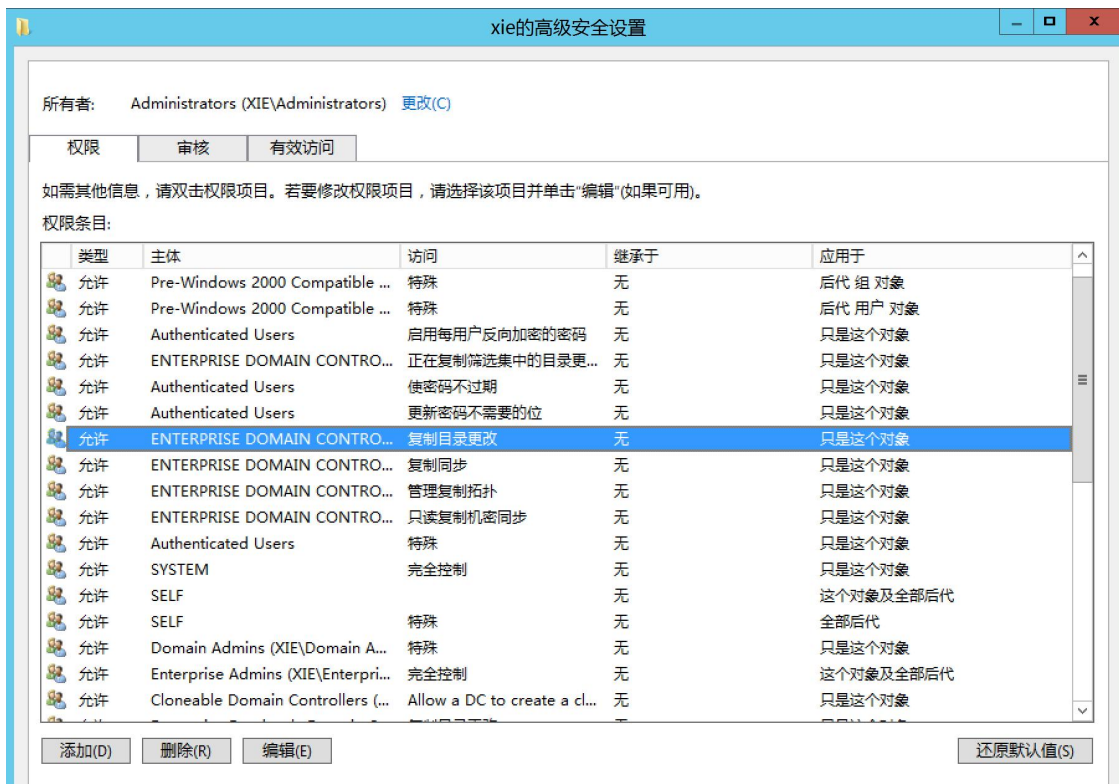
在“安全”选项卡即可看到不同用户对域对象的不同权限了。如图所示：



由于域对象有很多的权限，因此这不足以显示。我们可以点击高级查看更多的权限，如图所示：

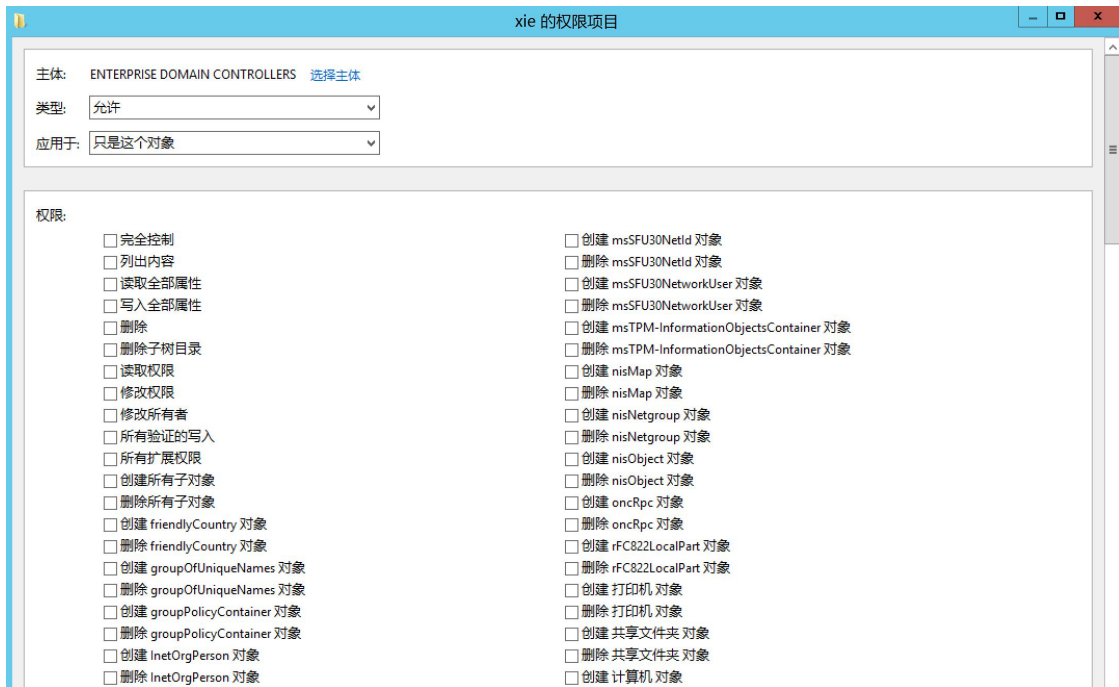


如图所示，即可看到不同主体所拥有的不同权限了。

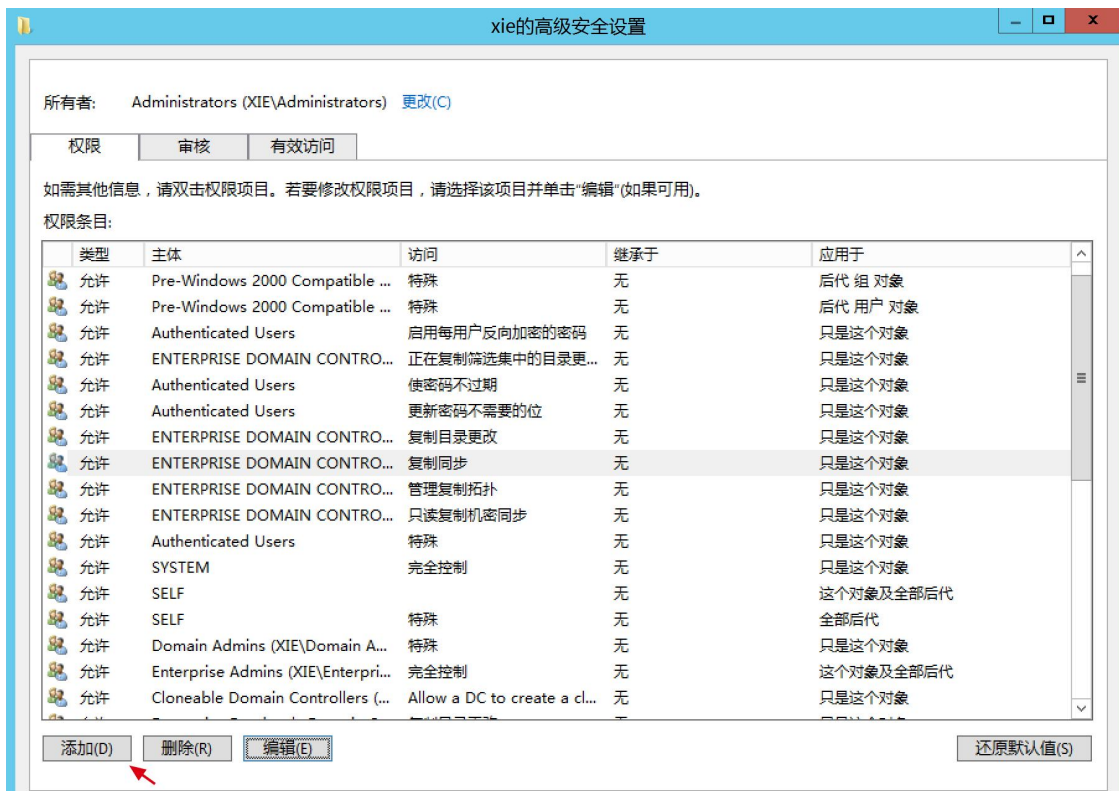


如果想查看某个主体拥有的具体权限, 可以点击编辑, 就可以看到详细的权限信息了。

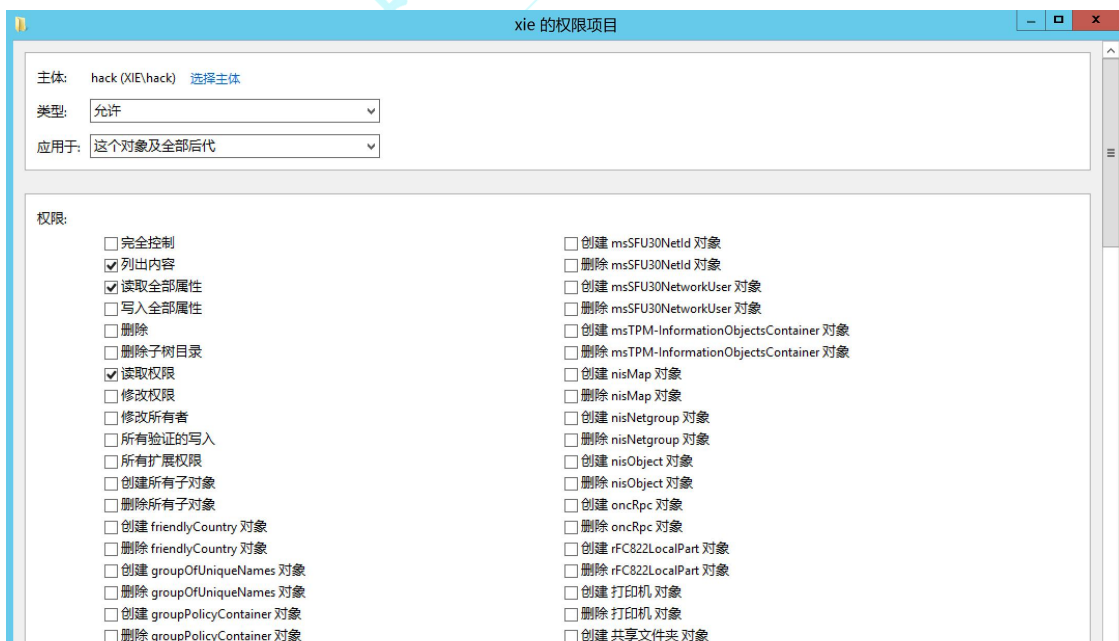
如图所示, 域对象除了具有基本权限外, 其还具有属性权限、扩展权限。



如果想添加指定用户对该域对象的权限，可以点击“添加”。如图所示：



在弹出的对话框中选择主体, 我这里选的是 hack 用户, 类型是允许, 权限信息自行勾选即可。如图所示:



2. Adfind 查询 ACL

Adfind 是一款优秀的 Ldap 查询工具，其支持对域内对象的 ACL 进行查询。-sddlfilter 参数支持使用 SDDL 语言格式过滤对象。格式如下：

```
-sddlfilter *****
                ~~~~~
```

后面跟的参数对应的是 ACE 条目相应的参数，需要说明的是，过滤的格式跟输出的格式要保持一致：

- 如果 -rawsddl ，最后一个参数是 sid 值，这个时候用 -sddlfilter 进行过滤的话，最后一个参数就要用 sid 的形式。
- 如果是 -sddl+++，最后一个参数是已经解析后的账号名，这个时候用 -sddlfilter 进行过滤的话，最后一个参数就要用账号名的形式。

注：普通域用户无法使用 adfind 进行 ACL 相关的查询！

(1) 查询指定对象的 ACL

使用 -b 参数指定要查询的对象，然后过滤 nTSecurityDescriptor 属性。使用 -sddl 进行显示，可以使用 + 使结果更易读，最多使用三个 +。具体 命令如下：

#查找指定对象的 ACL

```
AdFind.exe -b "CN=hack,CN=Users,DC=xie,DC=com" nTSecurityDescriptor -sddl
```

#查找指定对象的 ACL,使结果更直观

```
AdFind.exe -b "CN=hack,CN=Users,DC=xie,DC=com" nTSecurityDescriptor -sddl+
```

```
AdFind.exe -b "CN=hack,CN=Users,DC=xie,DC=com" nTSecurityDescriptor -sddl+
```

```
+
```

```
AdFind.exe -b "CN=hack,CN=Users,DC=xie,DC=com" nTSecurityDescriptor -sddl+
```

```
++
```

如图所示，查看 hack 用户的 ACL。


```
C:\Users\Administrator\Desktop>AdFind.exe -b "CN=hack,CN=Users,DC=xie,DC=com" nTSecurityDescriptor -sddl
AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020

Using server: AD.xie.com:389
Directory: Windows Server 2012 R2

dn:CN=hack,CN=Users,DC=xie,DC=com
>nTSecurityDescriptor: [OWNER] DA
>nTSecurityDescriptor: [GROUP] DA
>nTSecurityDescriptor: [DACL] AI(OA;RP;{4C164200-20C0-11D0-A768-00AA006E0529};;RS)(OA;RP;{5F202010-79A5-11D0-9020-00C04FC2D4CF};;RS)
6A9B11D-60AE-405A-B7E8-FF8A58D456D2};;S-1-5-32-560)(OA;RPWP;{6DB69A1C-9422-11D1-AEBD-0000F80367C1};;S-1-5-32-561)(OA;RPWP;{5805BC62-B
F-11D0-9819-00AA0040529B};;PS)(OA;CR;{AB721A56-1E2F-11D0-9819-00AA0040529B};;PS)(OA;RP;{59BA2F42-79A2-11D0-9020-00C04FC2D3CF};;AU)(OA
B886-944A-11D1-AEBD-0000F80367C1};;PS)(OA;RPWP;{E45795B2-9455-11D1-AEBD-0000F80367C1};;PS)(OA;RPWP;{E45795B3-9455-11D1-AEBD-0000F8036
69E6D-2CC7-11D2-854E-00A0C983F608};{BF967A86-0DE6-11D0-A285-00AA003049E2};ED)(OA;CIIID;RP;{B7C69E6D-2CC7-11D2-854E-00A0C983F608};{BF96
C6C-4DF4FDA78A35};{BF967A86-0DE6-11D0-A285-00AA003049E2};PS)(OA;CIIID;LCRPLORC;{4828CC14-1437-45BC-9B07-AD6F015E5F28};RU)(OA;CIIID;L
;PS)(OA;CIIID;RPWP;{91E647DE-D96F-4B70-9557-D63FF4F3CCD8};;PS)(A;CIIID;CCDCLCSWRPMDTLCDRSDRCWDWO;S-1-5-21-1313979556-3624129433-4055
>nTSecurityDescriptor: [SACL] AI(OU;CIIIDSA;WP;{F30E3BBE-9FF0-11D1-B603-0000F80367C1};{BF967AA5-0DE6-11D0-A285-00AA003049E2};WD)(OU;C
1 Objects returned
```

如图所示，更加直观的查看 hack 用户的 ACL。

```
C:\Users\Administrator\Desktop>AdFind.exe -b "CN=hack,CN=Users,DC=xie,DC=com" nTSecurityDescriptor -sddl+++
AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020

Using server: AD.xie.com:389
Directory: Windows Server 2012 R2

dn:CN=hack,CN=Users,DC=xie,DC=com
>nTSecurityDescriptor: [OWNER] XIE\Domain Admins
>nTSecurityDescriptor: [GROUP] XIE\Domain Admins
>nTSecurityDescriptor: [DACL] (FLAGS:INHERIT)
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[READ PROP];Account Restrictions;;XIE\RAS and IAS Servers
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[READ PROP];Logon Information;;XIE\RAS and IAS Servers
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[READ PROP];Group Membership;;XIE\RAS and IAS Servers
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[READ PROP];Remote Access Information;;XIE\RAS and IAS Servers
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[READ PROP][WRT PROP];userCertificate;;XIE\Cert Publishers
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[READ PROP];tokenGroupsGlobalAndUniversal;;BUILTIN\Windows Authorization Access Group
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[READ PROP][WRT PROP];terminalServer;;BUILTIN\Terminal Server License Servers
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[READ PROP][WRT PROP];Terminal Server License Server;;BUILTIN\Terminal Server License Servers
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[CTL];Change Password;Everyone
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[CTL];Change Password;NT AUTHORITY\SELF
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[CTL];Send As;;NT AUTHORITY\SELF
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[CTL];Receive As;;NT AUTHORITY\SELF
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[READ PROP];General Information;;NT AUTHORITY\Authenticated Users
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[READ PROP];Public Information;;NT AUTHORITY\Authenticated Users
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[READ PROP];Personal Information;;NT AUTHORITY\Authenticated Users
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[READ PROP];Web Information;;NT AUTHORITY\Authenticated Users
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[READ PROP][WRT PROP];Personal Information;;NT AUTHORITY\SELF
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[READ PROP][WRT PROP];Phone and Mail Options;;NT AUTHORITY\SELF
>nTSecurityDescriptor: [DACL] OBJ ALLOW;[READ PROP][WRT PROP];Web Information;;NT AUTHORITY\SELF
>nTSecurityDescriptor: [DACL] ALLOW;[FC];;;XIE\Domain Admins
>nTSecurityDescriptor: [DACL] ALLOW;[FC];;;BUILTIN\Account Operators
>nTSecurityDescriptor: [DACL] ALLOW;[READ];;;NT AUTHORITY\Authenticated Users
>nTSecurityDescriptor: [DACL] ALLOW;[LIST CHILDREN][READ PROP][LIST OBJ][READ];;;NT AUTHORITY\SELF
>nTSecurityDescriptor: [DACL] ALLOW;[FC];;;NT AUTHORITY\SYSTEM
```

(2) 查询指定对象在域内的 ACL

可以直接使用该对象的 SID 值或者使用该对象的名字执行如下命令即可查询指定对象在域内的 ACL。

#使用该对象的 SID 值

```
AdFind.exe -s subtree -b "DC=xie,DC=com" nTSecurityDescriptor -sddl -sddlfilter "S-1-5-21-1313979556-3624129433-4055459191-1105" -recmute
```



```

C:\Users\Administrator\Desktop>AdFind.exe -s subtree -b "DC=xie,DC=com" nTSecurityDescriptor -sddl+++ -sddlfilter ;;;"Replicating Directory Changes";; -recmute -resolvesids
AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020

Using server: AD.xie.com:389
Directory: Windows Server 2012 R2

dn:DC=xie,DC=com
>nTSecurityDescriptor: [DACL] 0B3 ALLOW;;[CTL];Replicating Directory Changes;;XIE\Enterprise Read-only Domain Controllers
>nTSecurityDescriptor: [DACL] 0B3 ALLOW;;[CTL];Replicating Directory Changes All;;XIE\Domain Controllers
>nTSecurityDescriptor: [DACL] 0B3 ALLOW;;[CTL];Replicating Directory Changes In Filtered Set;;BUILTIN\Administrators
>nTSecurityDescriptor: [DACL] 0B3 ALLOW;;[CTL];Replicating Directory Changes;;BUILTIN\Administrators
>nTSecurityDescriptor: [DACL] 0B3 ALLOW;;[CTL];Replicating Directory Changes All;;BUILTIN\Administrators
>nTSecurityDescriptor: [DACL] 0B3 ALLOW;;[CTL];Replicating Directory Changes In Filtered Set;;NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS
>nTSecurityDescriptor: [DACL] 0B3 ALLOW;;[CTL];Replicating Directory Changes;;NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS

dn:CN=Builtin,DC=xie,DC=com
>nTSecurityDescriptor: [DACL] 0B3 ALLOW;;[CTL];Replicating Directory Changes;;XIE\Enterprise Read-only Domain Controllers
>nTSecurityDescriptor: [DACL] 0B3 ALLOW;;[CTL];Replicating Directory Changes All;;XIE\Domain Controllers
>nTSecurityDescriptor: [DACL] 0B3 ALLOW;;[CTL];Replicating Directory Changes In Filtered Set;;BUILTIN\Administrators
>nTSecurityDescriptor: [DACL] 0B3 ALLOW;;[CTL];Replicating Directory Changes;;BUILTIN\Administrators
>nTSecurityDescriptor: [DACL] 0B3 ALLOW;;[CTL];Replicating Directory Changes All;;BUILTIN\Administrators
>nTSecurityDescriptor: [DACL] 0B3 ALLOW;;[CTL];Replicating Directory Changes In Filtered Set;;NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS
>nTSecurityDescriptor: [DACL] 0B3 ALLOW;;[CTL];Replicating Directory Changes;;NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS

2 Objects returned

C:\Users\Administrator\Desktop>AdFind.exe -s subtree -b "DC=xie,DC=com" nTSecurityDescriptor -sddl+++ -sddlfilter ;;;"Replicating Directory Changes All";; -recmute -resolvesids
AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020

Using server: AD.xie.com:389
Directory: Windows Server 2012 R2

dn:DC=xie,DC=com
>nTSecurityDescriptor: [DACL] 0B3 ALLOW;;[CTL];Replicating Directory Changes All;;XIE\Domain Controllers
>nTSecurityDescriptor: [DACL] 0B3 ALLOW;;[CTL];Replicating Directory Changes All;;BUILTIN\Administrators

dn:CN=Builtin,DC=xie,DC=com
>nTSecurityDescriptor: [DACL] 0B3 ALLOW;;[CTL];Replicating Directory Changes All;;XIE\Domain Controllers
>nTSecurityDescriptor: [DACL] 0B3 ALLOW;;[CTL];Replicating Directory Changes All;;BUILTIN\Administrators

2 Objects returned

```

3. PowerShell 脚本查询和修改 ACL

Empire 中的 powerview.ps1 脚本已经集成了 ACL 的相关功能。可以使用该脚本进行 ACL 的查询和修改，前提是该用户具备查询和修改的权限。

(1) 查询指定对象的 ACL

通过 Get-DomainObjectAcl 脚本执行如下命令查询 win2012R2 机器的 ACL，该结果不是每一条 ACE 显示，而是把每个 ACE 中的每个权限都单独显示出来。

```
Import-Module .\powerview.ps1
```

```
Get-DomainObjectAcl -Identity win2012R2 -ResolveGUIDs
```

如图所示，通过 Get-DomainObjectAcl 脚本查询 win2012R2 机器的 ACL。

```
PS C:\Users\Administrator\Desktop> Get-DomainObjectAcl -Identity win2012R2 -ResolveGUIDs
```

```
AceQualifier      : AccessAllowed
ObjectDN          : CN=WIN2012R2,CN=Computers,DC=xie,DC=com
ActiveDirectoryRights : WriteProperty
ObjectAceType     : User-Logon
ObjectSID         : S-1-5-21-1313979556-3624129433-4055459191-1106
InheritanceFlags  : None
BinaryLength      : 72
AceType           : AccessAllowedObject
ObjectAceFlags    : ObjectAceTypePresent, InheritedObjectAceTypePresent
IsCallback        : False
PropagationFlags  : None
SecurityIdentifier : S-1-5-21-1313979556-3624129433-4055459191-1105
AccessMask        : 32
AuditFlags        : None
IsInherited       : False
AceFlags          : None
InheritedObjectAceType : Computer
OpaqueLength      : 0

AceQualifier      : AccessAllowed
ObjectDN          : CN=WIN2012R2,CN=Computers,DC=xie,DC=com
ActiveDirectoryRights : WriteProperty
ObjectAceType     : Description
ObjectSID         : S-1-5-21-1313979556-3624129433-4055459191-1106
InheritanceFlags  : None
BinaryLength      : 72
AceType           : AccessAllowedObject
ObjectAceFlags    : ObjectAceTypePresent, InheritedObjectAceTypePresent
IsCallback        : False
PropagationFlags  : None
SecurityIdentifier : S-1-5-21-1313979556-3624129433-4055459191-1105
AccessMask        : 32
AuditFlags        : None
IsInherited       : False
AceFlags          : None
InheritedObjectAceType : Computer
OpaqueLength      : 0

AceQualifier      : AccessAllowed
ObjectDN          : CN=WIN2012R2,CN=Computers,DC=xie,DC=com
ActiveDirectoryRights : WriteProperty
```

我们来看看第一个权限表达的意思，主要看以下字段：

- AceQualifier 的值为 AccessAllowed，表示是访问允许的 ACE。
- ObjectDN 的值为 CN=WIN2012R2,CN=Computers,DC=xie,DC=com，表示的安全对象是机器 Win2012R2。
- ActiveDirectoryRights 的值为 WriteProperty，说明的是拥有写入属性
- ObjectAceType 的值为 User-Logon，说明的权限是用户登录。

- ObjectSID 代表的是安全对象也就是机器 Win2012R2 的 objectSid
- InheritanceFlags 表示的是继承标签
- AceType 的值为 AccessAllowedObject, 表示的是允许访问对象类型的 ACE, 与 AceQualifier 类似
- ObjectAceFlags 表示的是对象 ACE 类型
- SecurityIdentifier 表示的是安全主体的 SID, 通过查询 S-1-5-21-1313979556-3624129433-4055459191-1105 发现其对应的域用户为 xie\hack
- IsInherited 表示的是该 ACE 是否可继承
- InheritedObjectAceType 表示的是继承对象 ACE 类型

最终从下面的权限信息我们可以知道, xie\hack 用户拥有登录 WIN2012R2 机器的权限。

```

AceQualifier           : AccessAllowed
ObjectDN               : CN=WIN2012R2,CN=Computers,DC=xie,DC=com
ActiveDirectoryRights  : WriteProperty
ObjectAceType          : User-Logon
ObjectSID              : S-1-5-21-1313979556-3624129433-4055459191-1106
InheritanceFlags       : None
BinaryLength           : 72
AceType                : AccessAllowedObject
ObjectAceFlags         : ObjectAceTypePresent, InheritedObjectAceTypePresent
IsCallback             : False
PropagationFlags       : None
SecurityIdentifier     : S-1-5-21-1313979556-3624129433-4055459191-1105
AccessMask             : 32
AuditFlags             : None
IsInherited            : False
  
```

AceFlags : None
InheritedObjectAceType : Computer
OpaqueLength : 0

(2) 添加指定用户对指定域对象的完全控制权限

通过 powerview.ps1 脚本执行如下命令添加指定 hack 用户对指定域对象 xie.com 的完全访问权限，该操作需要高权限。

```
Import-Module .\powerview.ps1
```

#添加用户 hack 对指定域对象 xie.com 的完全访问权限

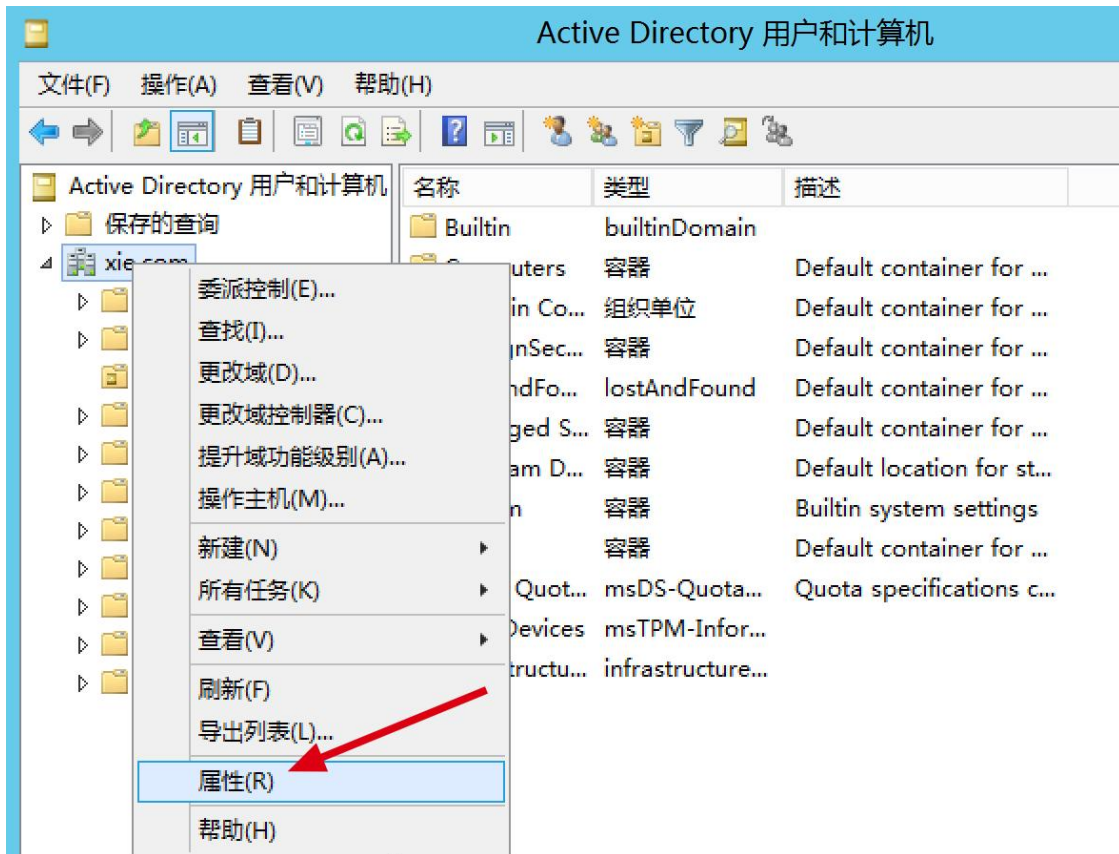
```
Add-DomainObjectAcl -TargetIdentity 'DC=xie,DC=com' -PrincipalIdentity hack -  
Rights All -Verbose
```

如图所示，通过 Get-DomainObjectAcl 脚本添加指定 hack 用户对指定域对象 xie.com 的完全访问权限。

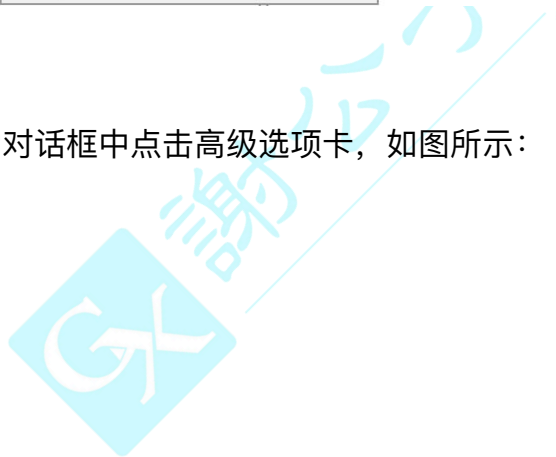
```
PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1  
PS C:\Users\Administrator\Desktop> Add-DomainObjectAcl -TargetIdentity 'DC=xie,DC=com' -PrincipalIdentity hack -Rights All -Verbose  
VERBOSE: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=XIE,DC=COM  
VERBOSE: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(samAccountName=hack)(name=hack)(displayname=hack))))  
VERBOSE: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=XIE,DC=COM  
VERBOSE: [Get-DomainObject] Extracted domain 'xie.com' from 'DC=xie,DC=com'  
VERBOSE: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=xie,DC=com  
VERBOSE: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(distinguishedname=DC=xie,DC=com))))  
VERBOSE: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com 'All' on DC=xie,DC=com  
VERBOSE: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '00000000-0000-0000-0000-000000000000' on DC=xie,DC=com
```

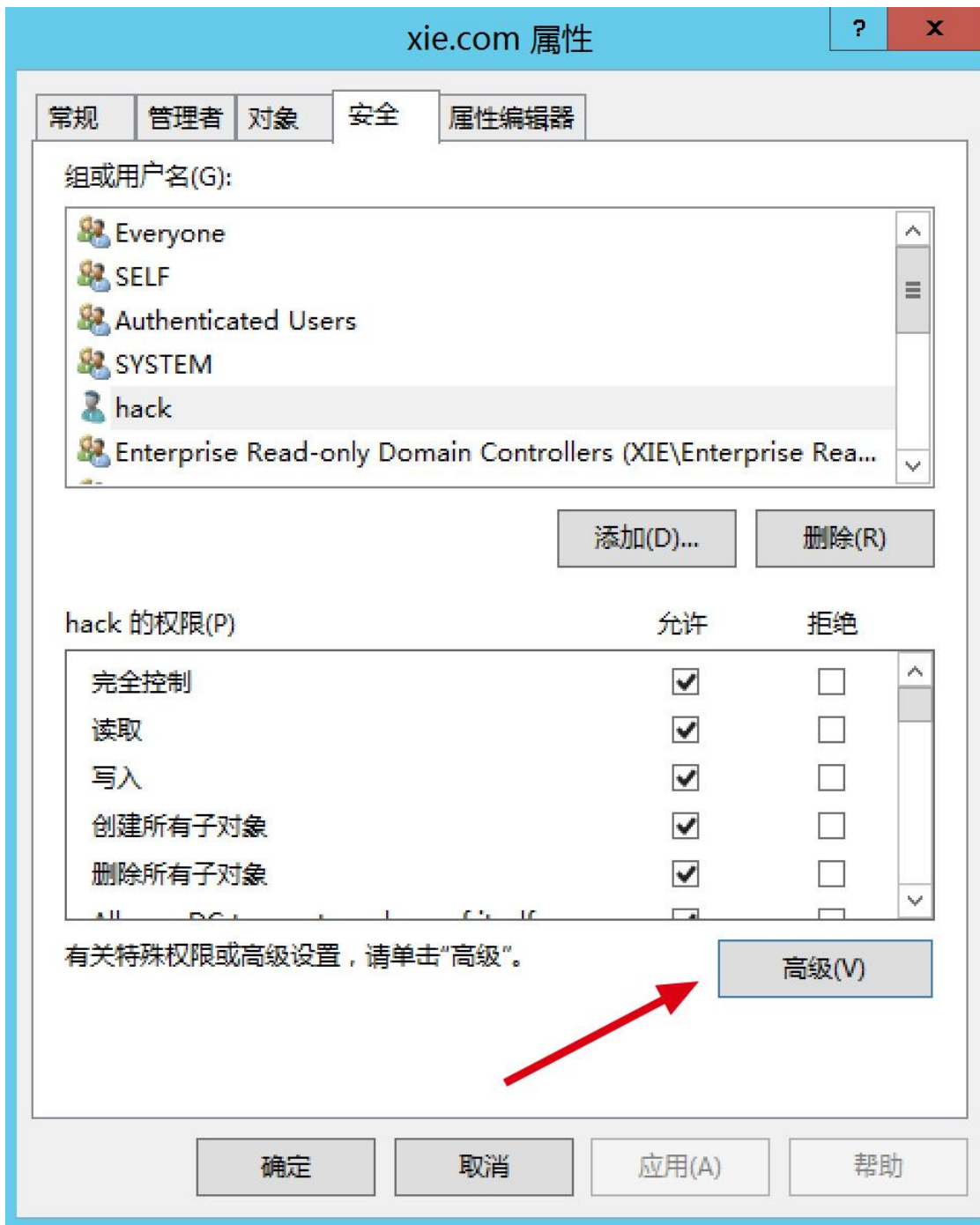
添加完成后，我们可以去查询下域 xie.com 的权限，看 hack 用户是否对其拥有完全访问权限。

如图所示，打开 Active Directory 用户和计算机窗口，右键 xie.com，点击属性。



在弹出的对话框中点击高级选项卡，如图所示：





如图所示，可以看到 hack 用户对该安全对象具有完全控制的权限了。



(3) 移除指定用户对指定域对象的完全控制权限

通过 Remove-DomainObjectAcl 脚本执行如下命令移除指定 hack 用户对指定域对象 xie.com 的完全访问权限，该操作需要高权限。

```
Import-Module .\powerview.ps1
```

#移除用户 hack 对指定域对象 xie.com 的完全访问权限

```
Remove-DomainObjectAcl -TargetIdentity 'DC=xie,DC=com' -PrincipalIdentity hac  
k -Rights All -Verbose
```

如图所示，通过 Remove-DomainObjectAcl 脚本移除指定 hack 用户对指定域对象 xie.com 的完全访问权限。

```
PS C:\Users\Administrator\Desktop> Remove-DomainObjectAcl -TargetIdentity 'DC=xie,DC=com' -PrincipalIdentity hack -Rights All -Verbose
VERBOSE: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=XIE,DC=COM
VERBOSE: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(samAccountName=hack)(name=hack)(displayName=hack))))
VERBOSE: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=XIE,DC=COM
VERBOSE: [Get-DomainObject] Extracted domain 'xie.com' from 'DC=xie,DC=com'
VERBOSE: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=xie,DC=com
VERBOSE: [Get-DomainObject] Get-DomainObject filter string: (&(|(|distinguishedname=DC=xie,DC=com)))
VERBOSE: [Remove-DomainObjectAcl] Removing principal CN=hack,CN=Users,DC=xie,DC=com 'All' from DC=xie,DC=com
VERBOSE: [Remove-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '00000000-0000-0000-0000-000000000000' on DC=xie,DC=com
True
```

(4) 添加指定用户对指定域对象的指定权限

通过 Add-DomainObjectAcl 脚本执行如下命令添加指定 hack 用户对指定域对象 xie.com 的 DCSync 权限，该操作需要高权限。

```
Import-Module .\powerview.ps1
```

#添加用户 hack 对指定域对象 xie.com 的 DCSync 权限

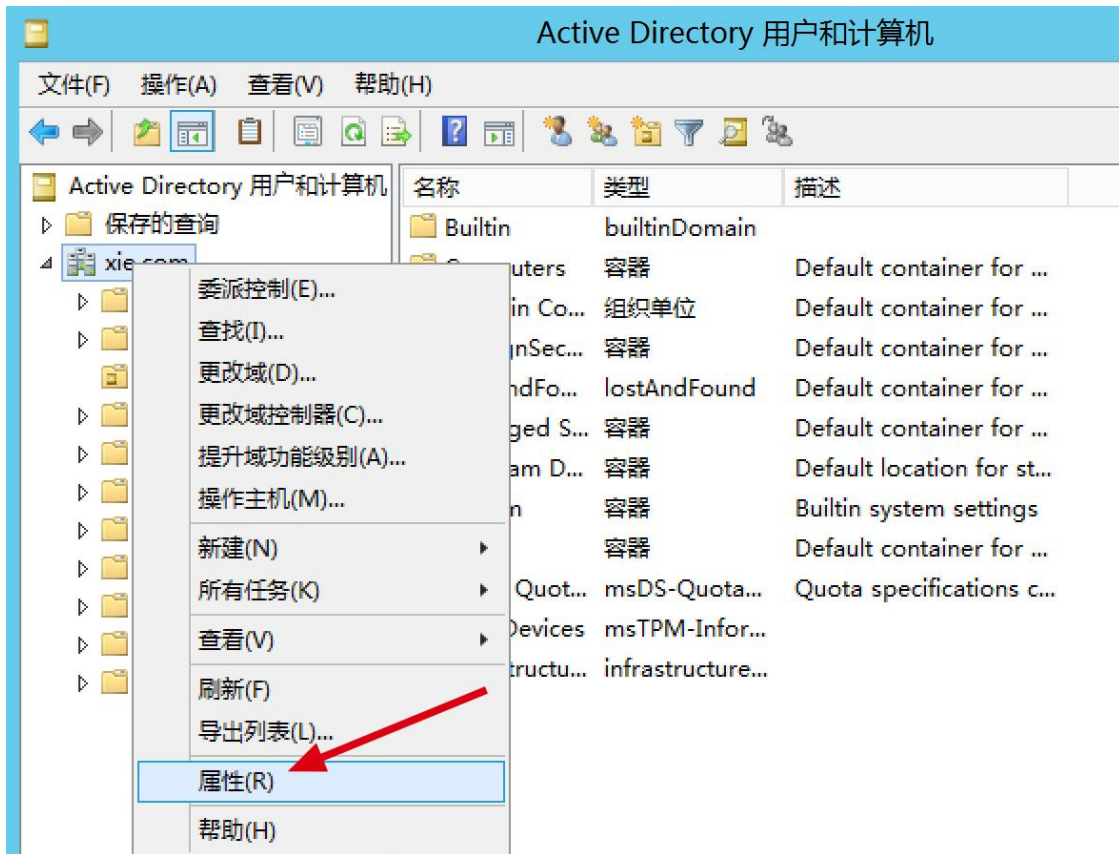
```
Add-DomainObjectAcl -TargetIdentity 'DC=xie,DC=com' -PrincipalIdentity hack -Rights DCSync -Verbose
```

如图所示，通过 Add-DomainObjectAcl 脚本添加指定 hack 用户对指定域对象 xie.com 的 DCSync 权限。

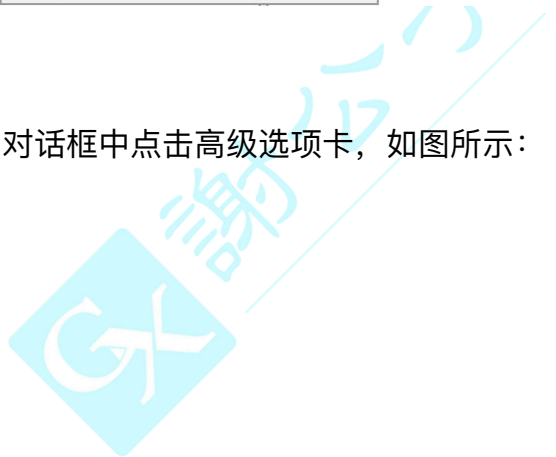
```
PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Add-DomainObjectAcl -TargetIdentity 'DC=xie,DC=com' -PrincipalIdentity hack -Rights DCSync -Verbose
详细信息: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(samAccountName=hack)(name=hack)(displayName=hack))))
详细信息: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Extracted domain 'xie.com' from 'DC=xie,DC=com'
详细信息: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=xie,DC=com
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(distinguishedname=DC=xie,DC=com))))
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com 'DCSync' on DC=xie,DC=com
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '1131f6aa-9c07-11d1-f79f-00c04fc2dcd2' on DC=xie,DC=com
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' on DC=xie,DC=com
详细信息: [Add-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '89e95b76-444d-4c62-991a-0facbeda640c' on DC=xie,DC=com
```

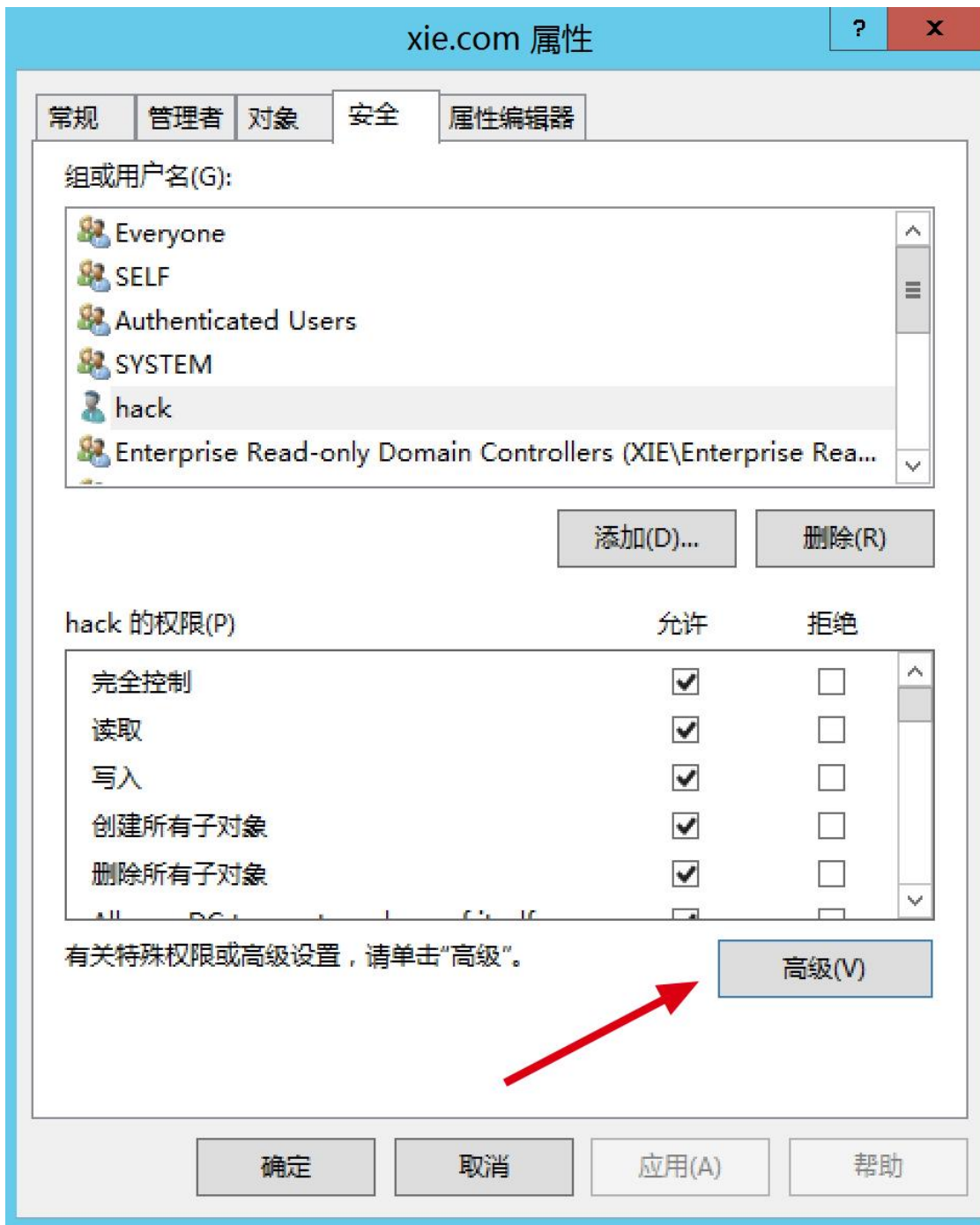
添加完成后，我们可以去查询下域 xie.com 的权限，看 hack 用户是否对其拥有 DCSync 权限。

如图所示，打开 Active Directory 用户和计算机窗口，右键 xie.com，点击属性。

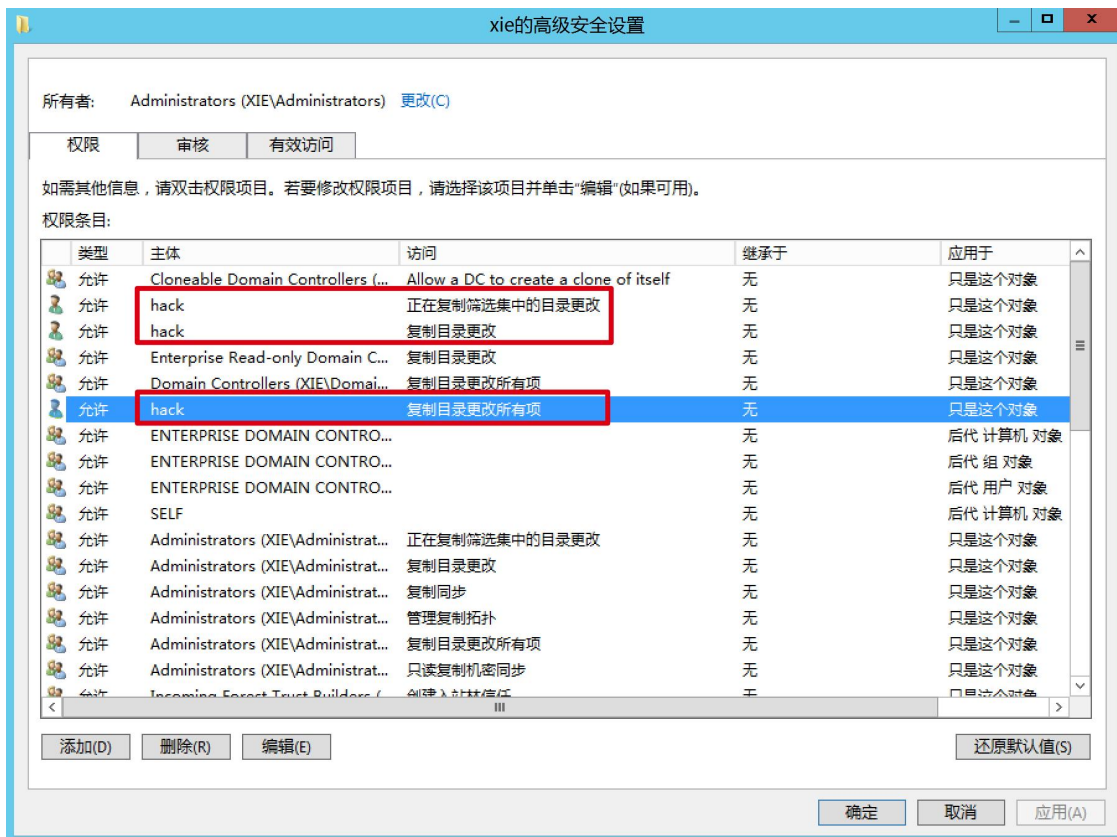


在弹出的对话框中点击高级选项卡，如图所示：





如图所示，然可以看到 hack 用户对该安全对象具有复制目录更改、复制目录更改所有项、以及复制筛选集中的目录更改权限(也就是 DCSync 权限)了。



(5) 移除指定用户对指定域对象的指定权限

通过 Remove-DomainObjectAcl 脚本执行如下命令移除指定 hack 用户对指定域对象 xie.com 的 DCSync 权限，该操作需要高权限。

```
Import-Module .\powerview.ps1
```

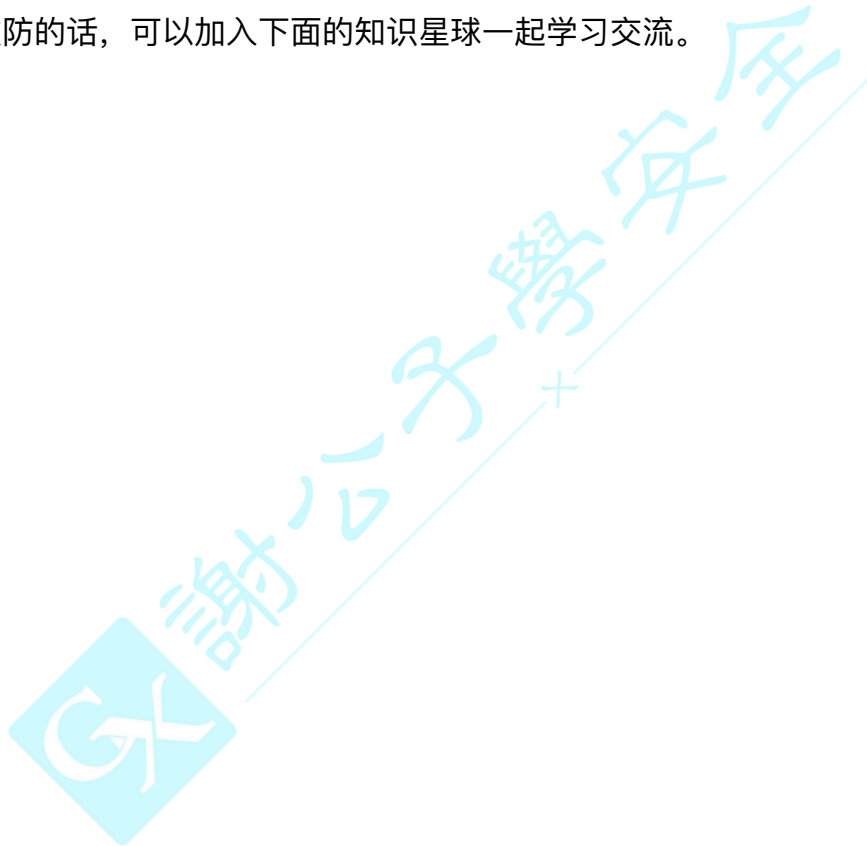
#移除用户 hack 对指定域对象 xie.com 的 DCSync 权限

```
Remove-DomainObjectAcl -TargetIdentity 'DC=xie,DC=com' -PrincipalIdentity hac
k -Rights DCSync -Verbose
```

如图所示，通过 Remove-DomainObjectAcl 脚本移除指定 hack 用户对指定域对象 xie.com 的 DCSync 权限。

```
PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> Remove-DomainObjectAcl -TargetIdentity 'DC=xie,DC=com' -PrincipalIdentity hack -Rights DCSync -Verbose
详细信息: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(|(samAccountName=hack)(name=hack)(displayName=hack))))
详细信息: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=XIE,DC=COM
详细信息: [Get-DomainObject] Extracted domain 'xie.com' from 'DC=xie,DC=com'
详细信息: [Get-DomainSearcher] search base: LDAP://AD.XIE.COM/DC=xie,DC=com
详细信息: [Get-DomainObject] Get-DomainObject filter string: (&(|(|distinguishedname=DC=xie,DC=com)))
详细信息: [Remove-DomainObjectAcl] Removing principal CN=hack,CN=Users,DC=xie,DC=com 'DCSync' from DC=xie,DC=com
详细信息: [Remove-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '1131f6aa-9c07-11d1-f79f-00c04fc2dcd2' on DC=xie,DC=com
True
详细信息: [Remove-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '1131f6ad-9c07-11d1-f79f-00c04fc2dcd2' on DC=xie,DC=com
True
详细信息: [Remove-DomainObjectAcl] Granting principal CN=hack,CN=Users,DC=xie,DC=com rights GUID '89e95b76-444d-4c62-991a-0facbeda640c' on DC=xie,DC=com
True
```

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。





谢公子

我加入了这个星球，邀你一起学习



域渗透攻防指南

星主：谢公子

60+

成员数量

30+

内容数量

306

运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199

微信扫码加入星球



相关文章: <https://www.anquanke.com/post/id/212163#h2-23>

<https://youngrichog.github.io/2020/02/08/Active-Directory-ACL-相关安全研究/>

https://www.specterops.io/assets/resources/an_ace_up_the_sleeve.pdf

<https://wald0.com/?p=112>

[https://docs.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2003/cc780957\(v=ws.10\)?redirectedfrom=MSDN](https://docs.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2003/cc780957(v=ws.10)?redirectedfrom=MSDN)

<https://docs.microsoft.com/en-us/windows/security/identity-protection/access-control/security-identifiers>

https://docs.microsoft.com/en-us/openspecs/windows_protocols/ms-adts/d2435927-0999-4c62-8c6d-13ba31a52e1a

<https://docs.microsoft.com/zh-cn/windows/win32/secauthz/security-descriptors>

<https://docs.microsoft.com/en-us/windows/win32/adschema/extended-rights>

<https://docs.microsoft.com/zh-cn/windows/win32/secauthz/how-dacls-control-access-to-an-object>

<https://docs.microsoft.com/zh-cn/windows/win32/secauthz/security-descriptor-definition-language>

<https://docs.microsoft.com/en-us/windows/win32/secauthz/ace-strings>

<https://docs.microsoft.com/en-us/windows/win32/adschema/attributes-all>

<https://docs.microsoft.com/zh-cn/windows-server/administration/windows-commands/icacls>